

Data Destruction & Retention

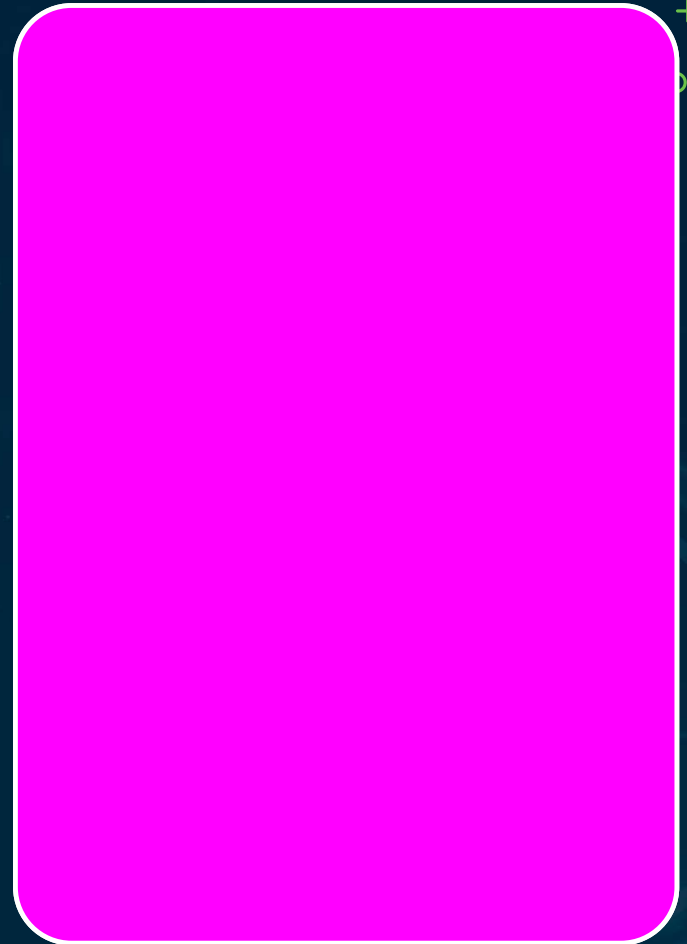
Chapter 03 · Episode 1 — Dr. Michael Solomon

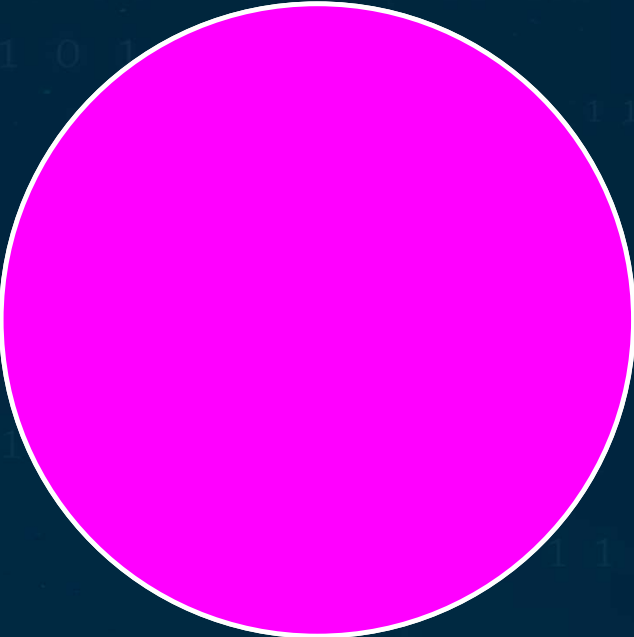


Designing the Program

Governance → operational practice

Policies, structures, metrics, response





What This Episode Covers

1. Retention schedule by asset type
2. 3 destruction methods + certificate
3. 4 AI challenges · 5 policy components

Retention Obligations



DATA

Training data

MODEL

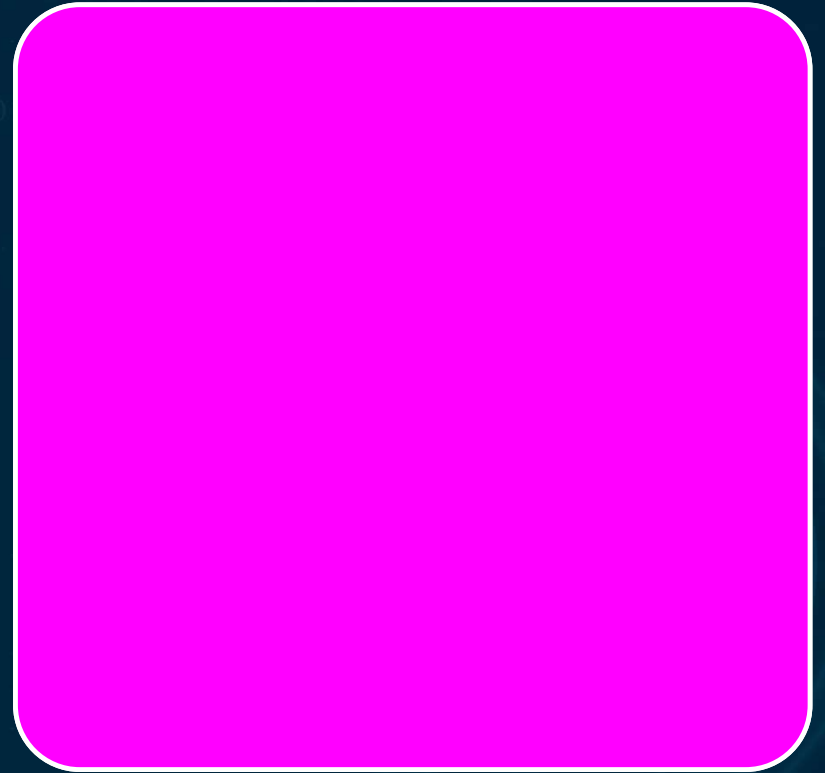
Model artifacts

LOGS

Inference logs

≠

Different basis & periods

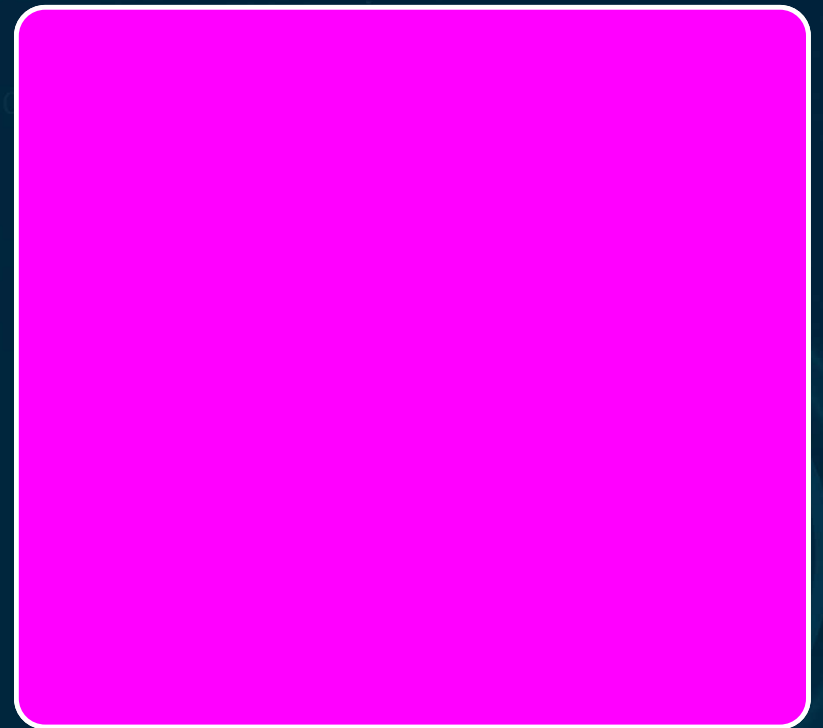


TRAINING DATA

Retain for model use + legal hold

Minimum = forensic investigation

Max bounded by GDPR storage limitation

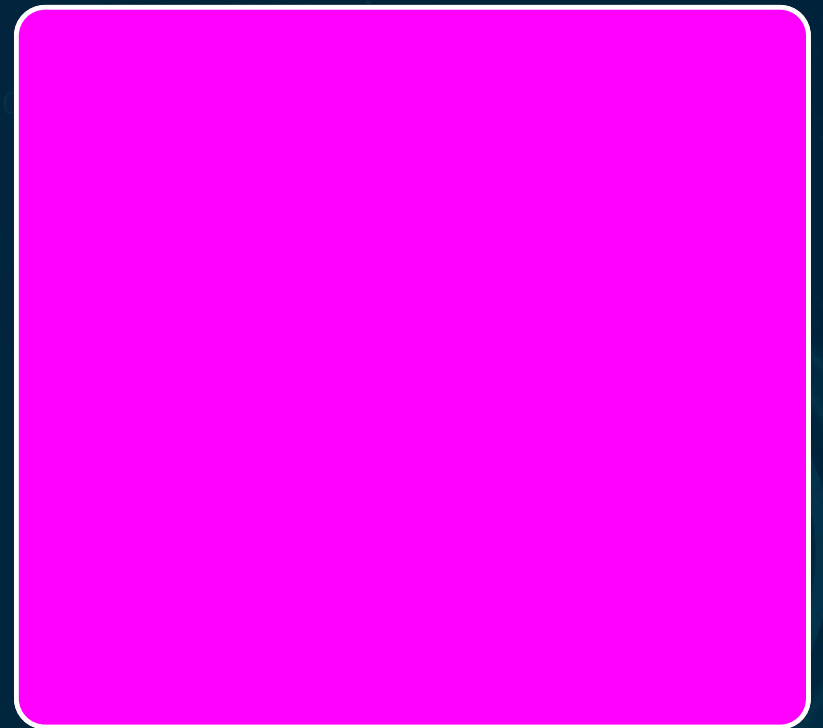


MODEL ARTIFACTS

Weights, versions, registry entries

Retain production versions in service

Post-retirement 4–5 yrs (high-risk)



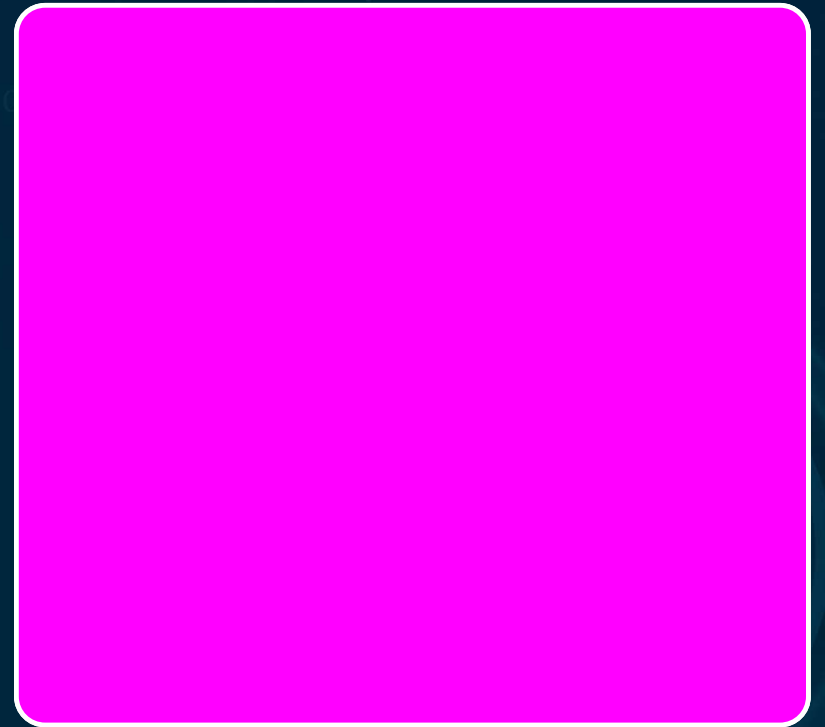
DESTRUCTION PROCEDURES



Standard deletion $\neq$ embedded data

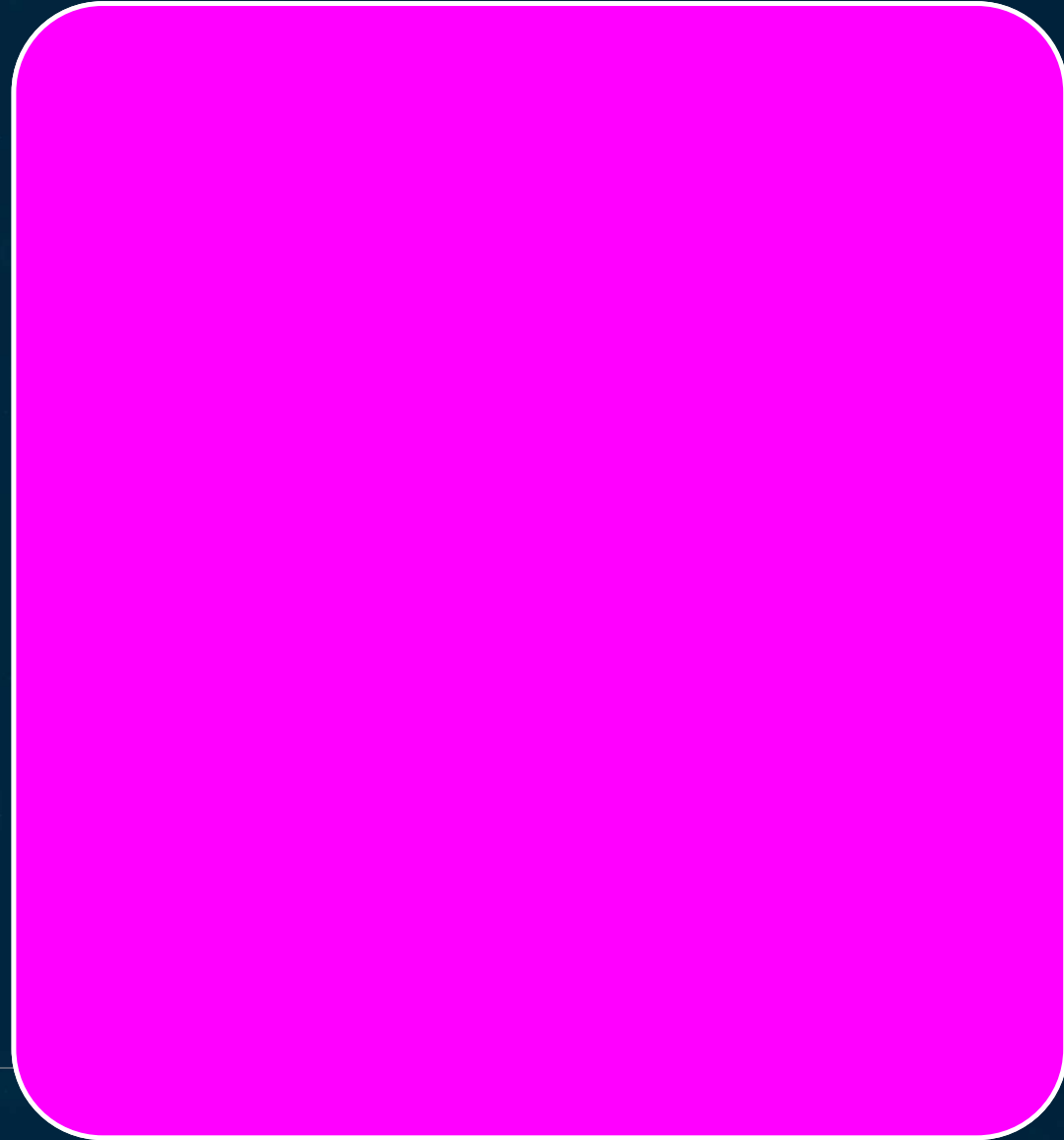
Vendor: written confirmation

Self-host: secure weight deletion



Destruction Records = Evidence

Produced for regulators (GDPR)

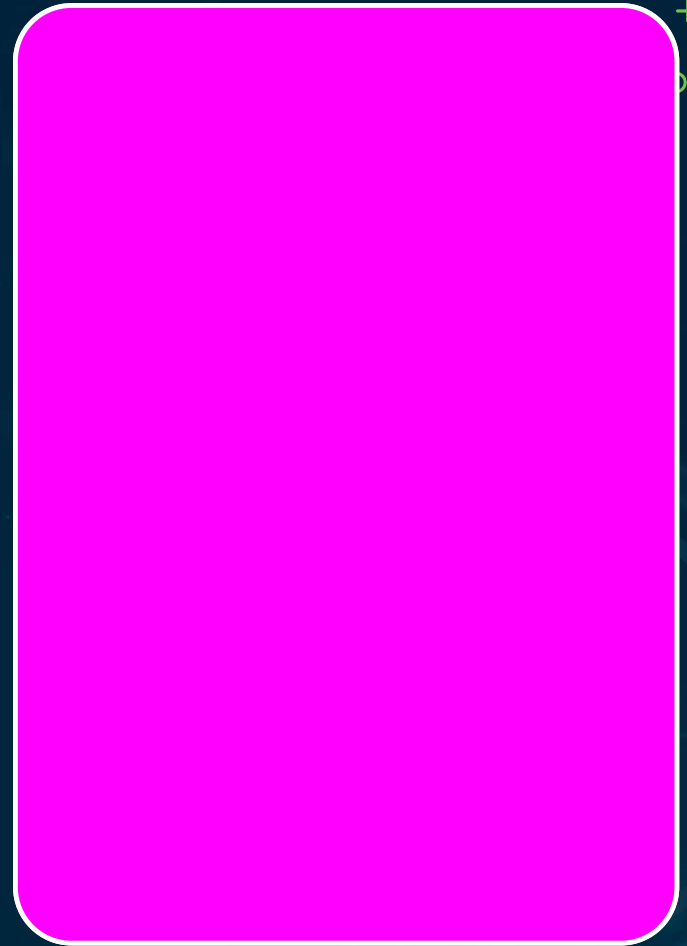


Recap

3 retention categories & periods

Destruction procedures

6 min · data persists in weights



Developing the AI Security Program Plan

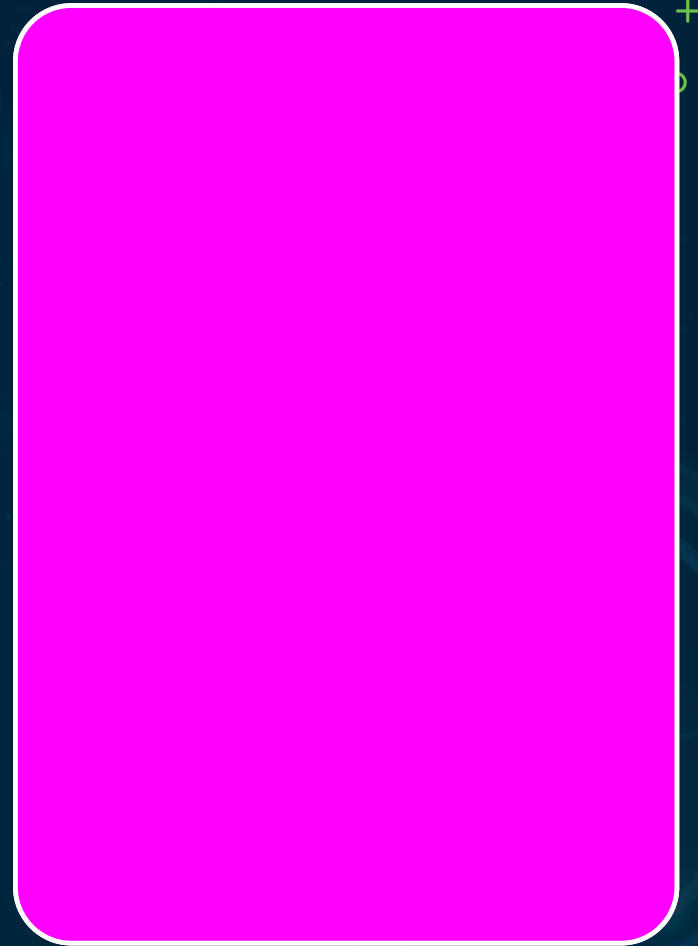
Chapter 03 · Episode 2 — Dr. Michael Solomon



The Master Document

Translates governance → operational program

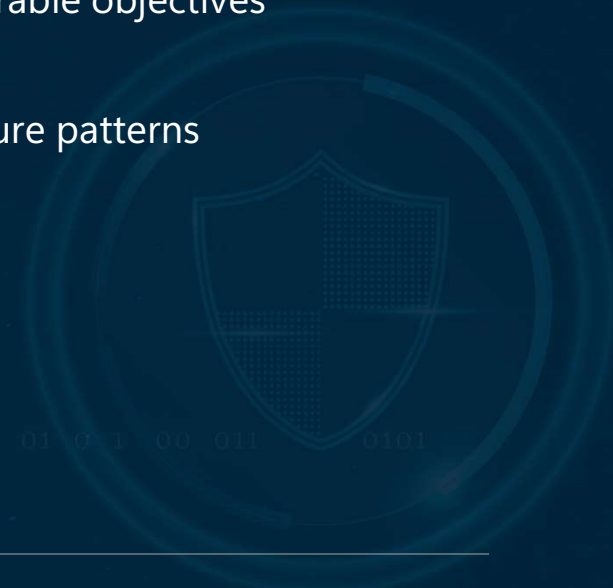
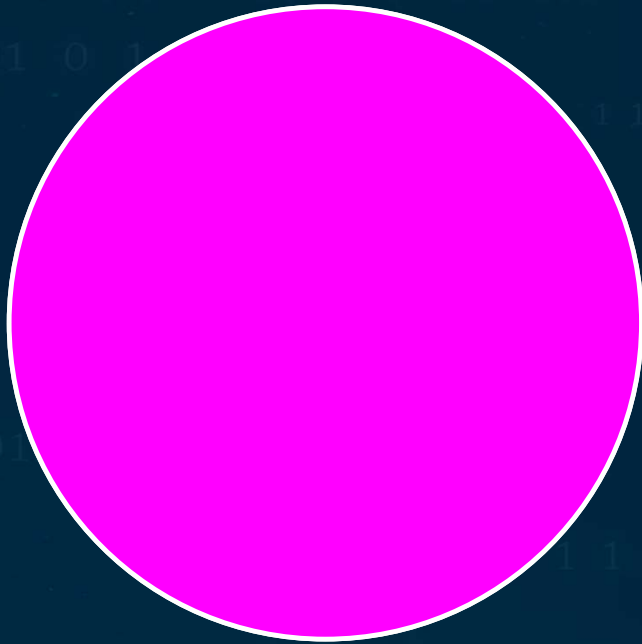
References every other document





What This Episode Covers

1. 7 components · measurable objectives
2. Scope & resourcing
3. 6-stage process · 4 failure patterns



Required Sections 1–4



1

Scope

2

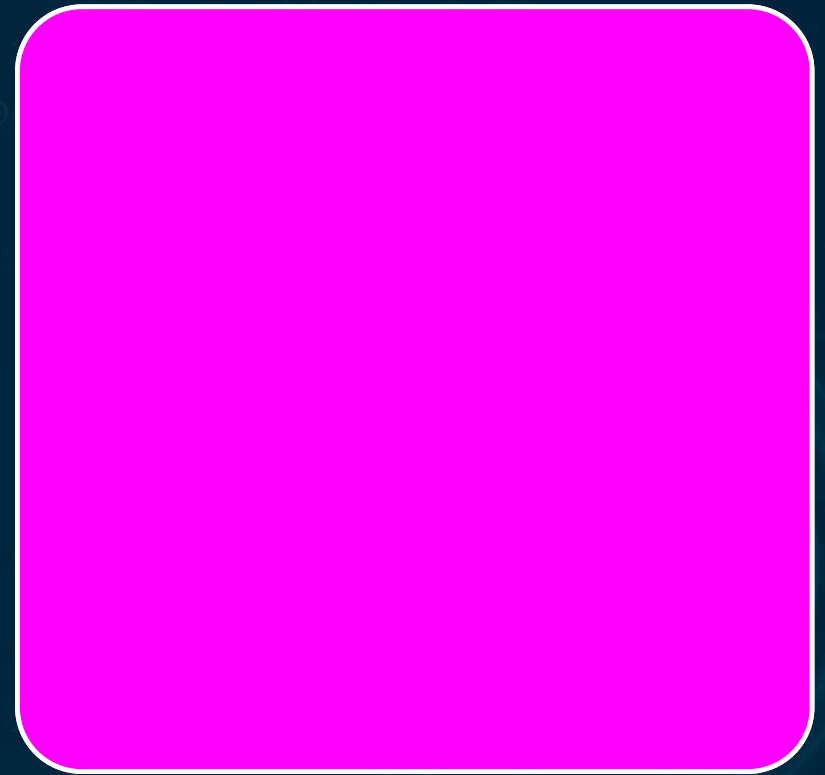
Governance structure

3

Framework alignment

4

Risk appetite



Required Sections 5–7



5

Asset inventory reference

6

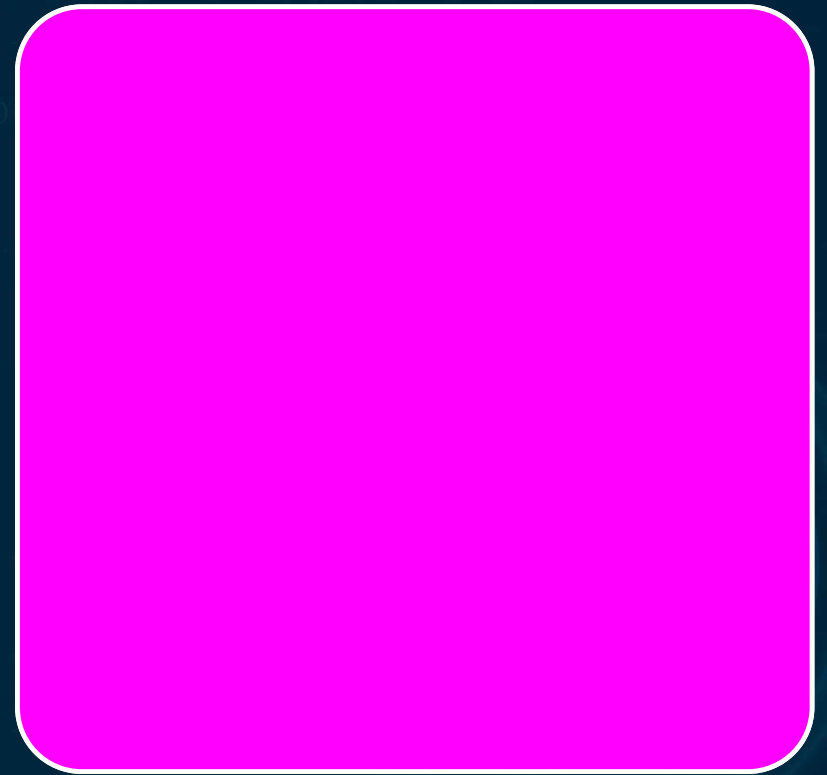
Control framework

7

Monitoring approach

...

Reporting structure

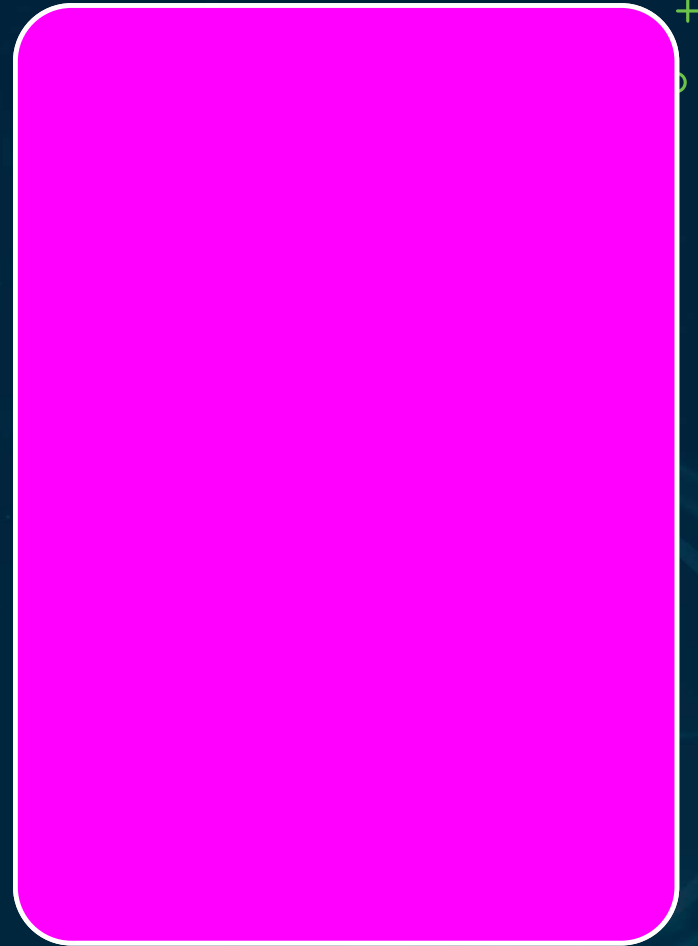


Each Section Carries

An owner

A review cadence

A last-review date — navigational

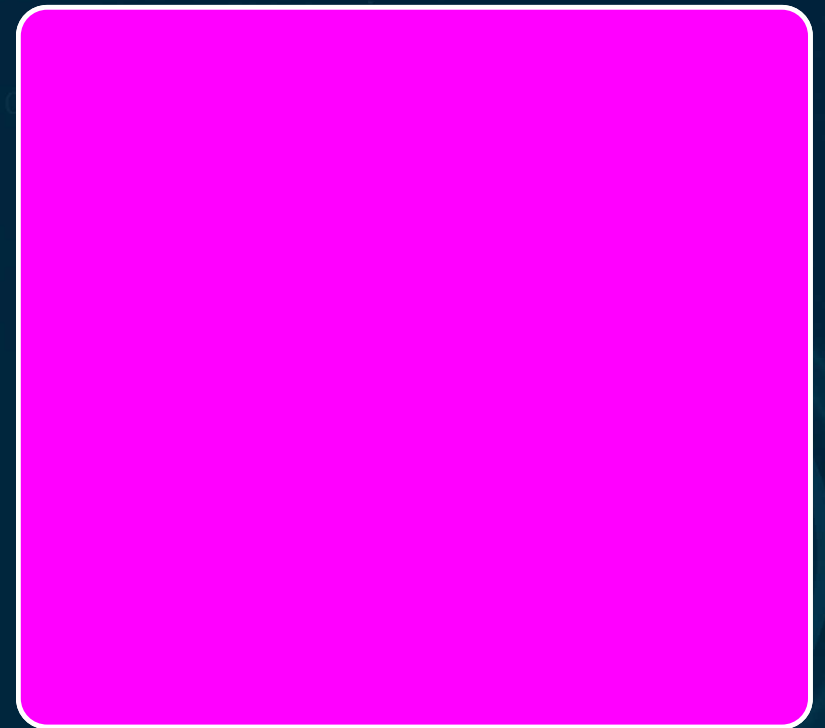


US REGULATORY NOTE

Federal contractors → OMB AI guidance

Financial → OCC / FDIC

Structure is jurisdiction-neutral

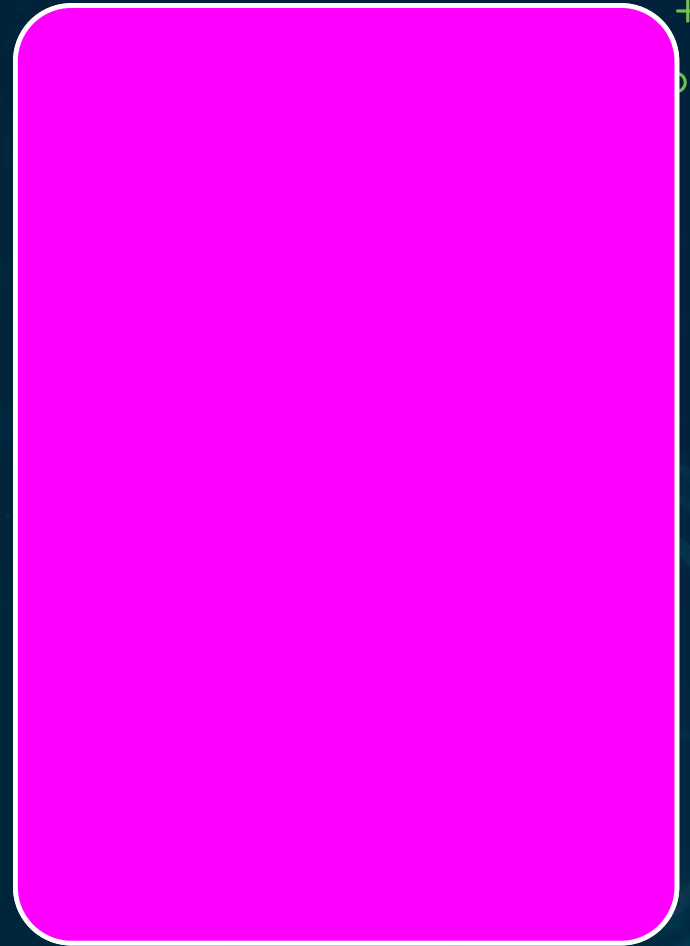


The Governance Thread

Connects all six modules

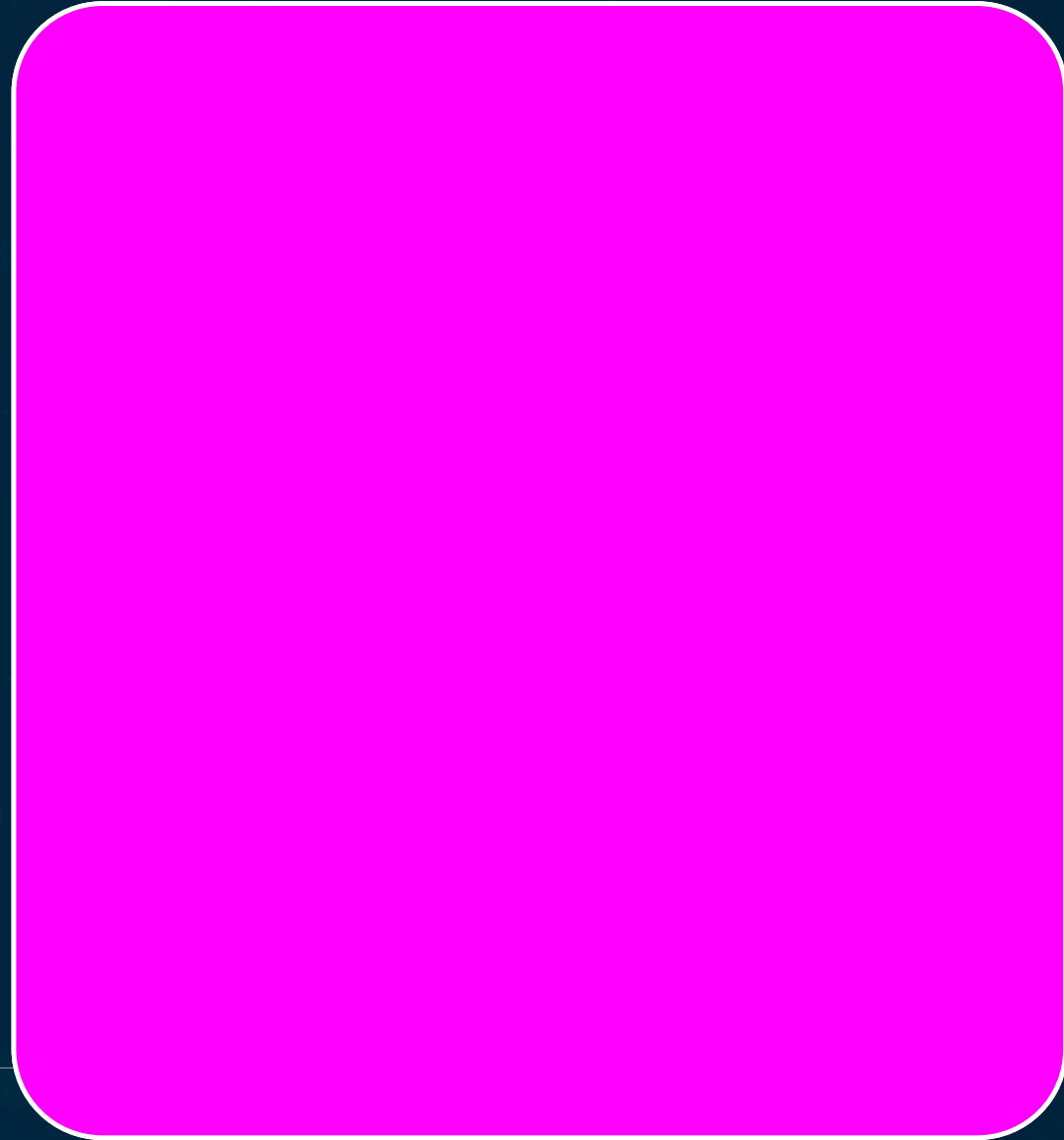
Control catalog · monitoring · IR

One authoritative coordination doc



Four Failure Patterns

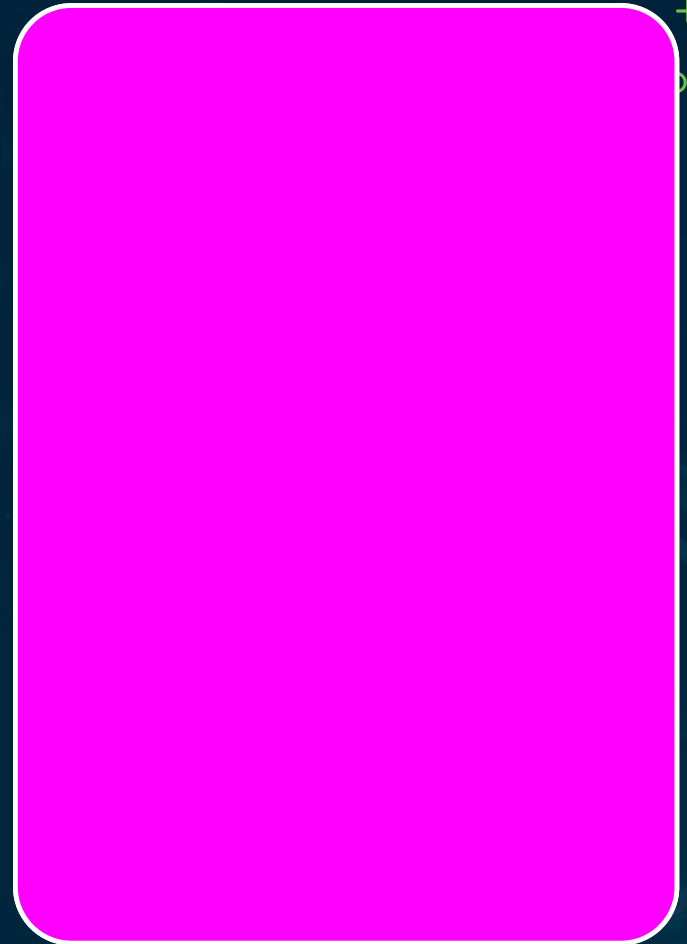
A diagnosis and fix for each



Failure Patterns 1–2

No executive endorsement

Scope too narrow — excludes dev/test
(where most incidents originate)

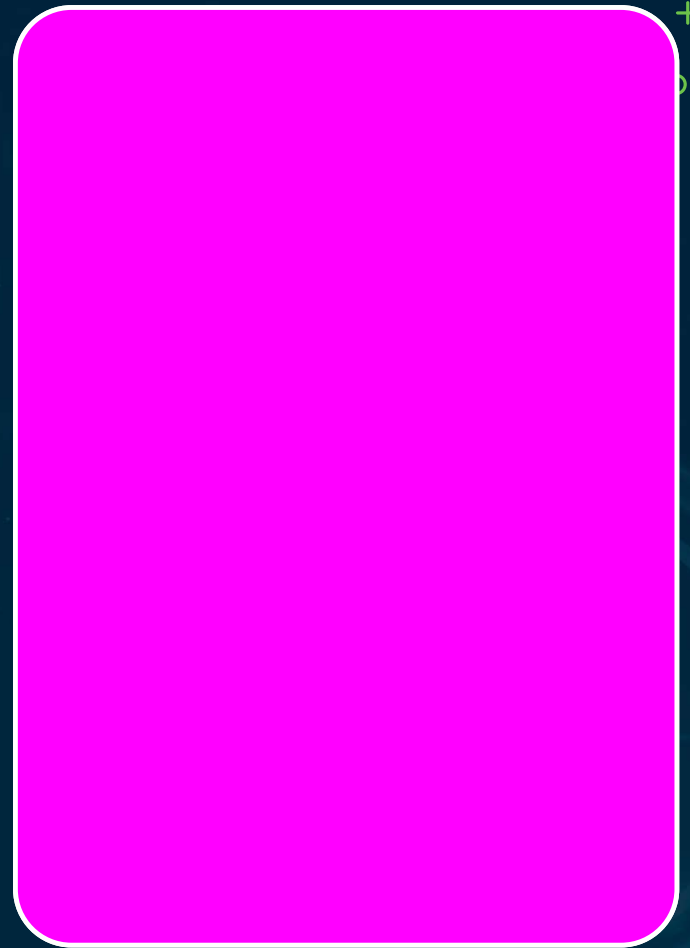


Failure Patterns 3–4

Objectives without metrics

Stale scope after material change

No baseline, no deadline

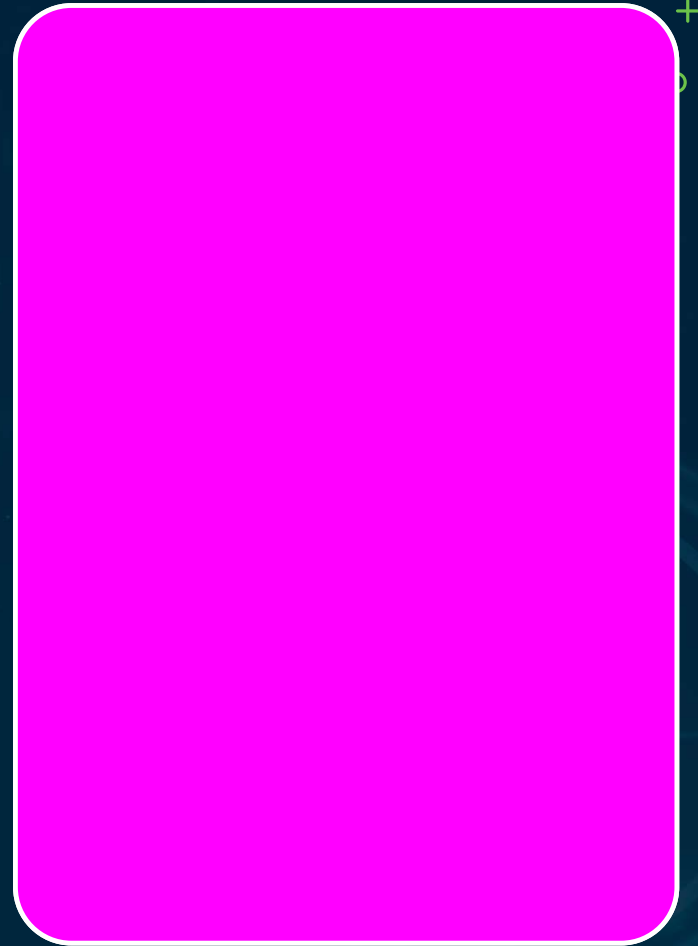


Recap

7 components · SMART objectives

Exec approval — not just CISO

Material change → mandatory review



Aligning AI Security with Enterprise InfoSec

Chapter 03 · Episode 3 — Dr. Michael Solomon

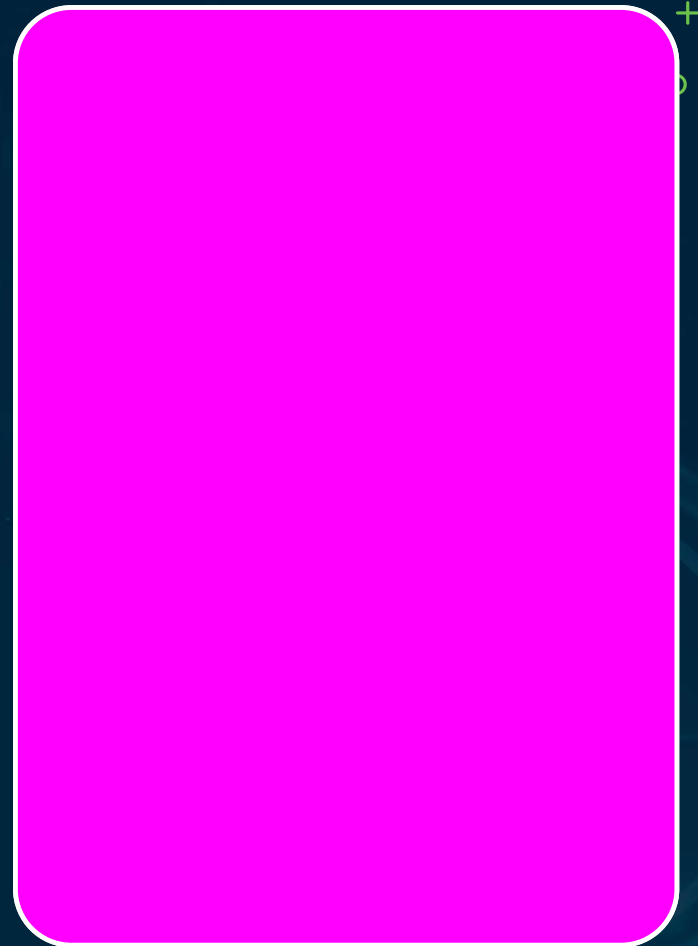


Extend, Don't Replace

AI security extends enterprise security

Not a separate silo

Misalignment = duplicate structures + gaps

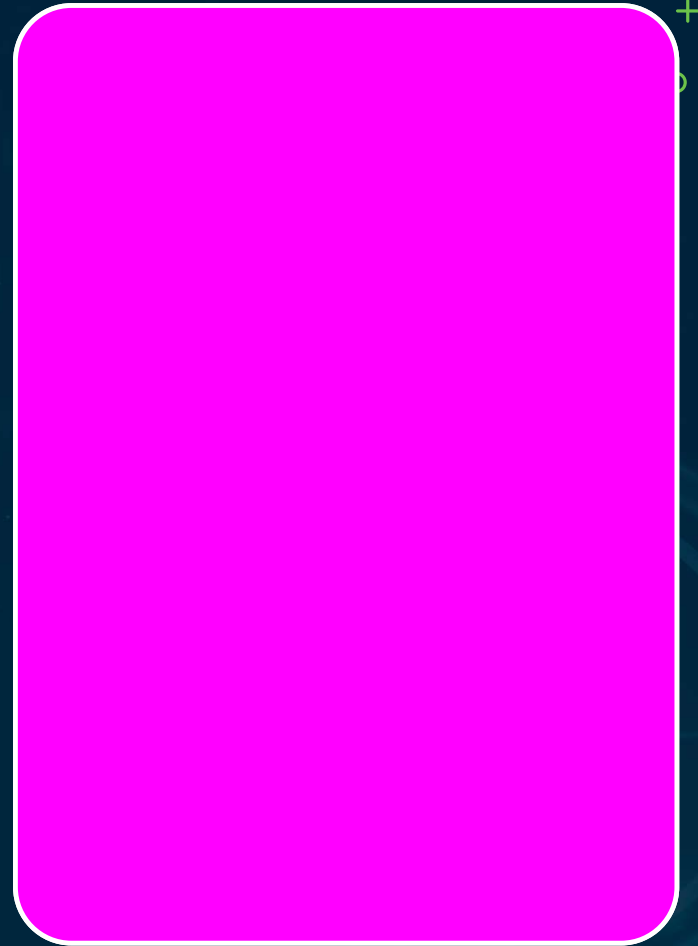


1 · Risk Register

AI register feeds the enterprise register

Above-appetite risks escalate up

A subset, not a replacement

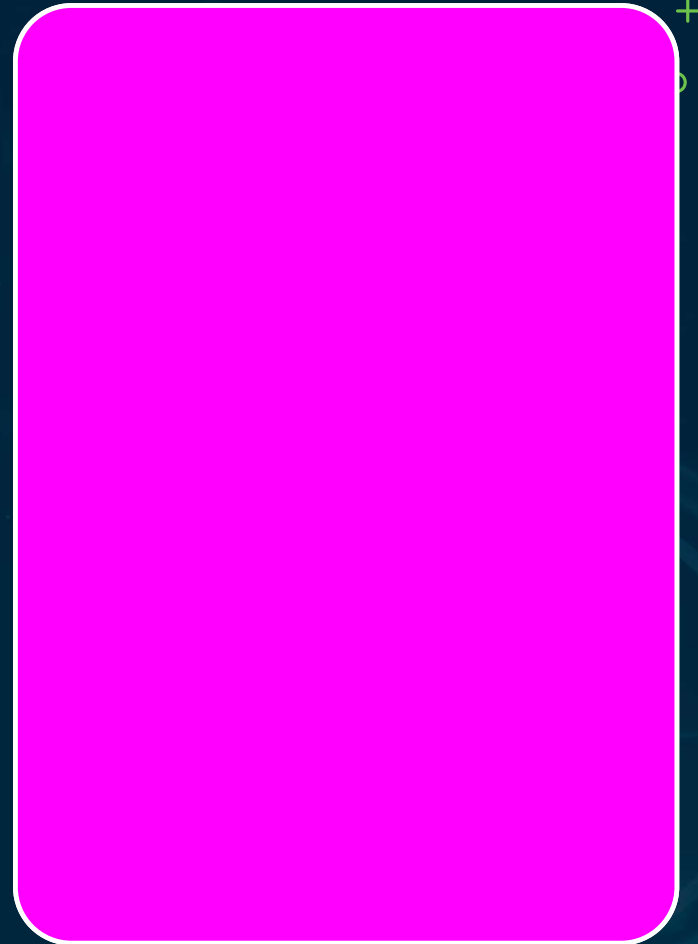


2 · Incident Response

Integrated with enterprise IR

Personal data → GDPR notification

Category A → CISO + board notify

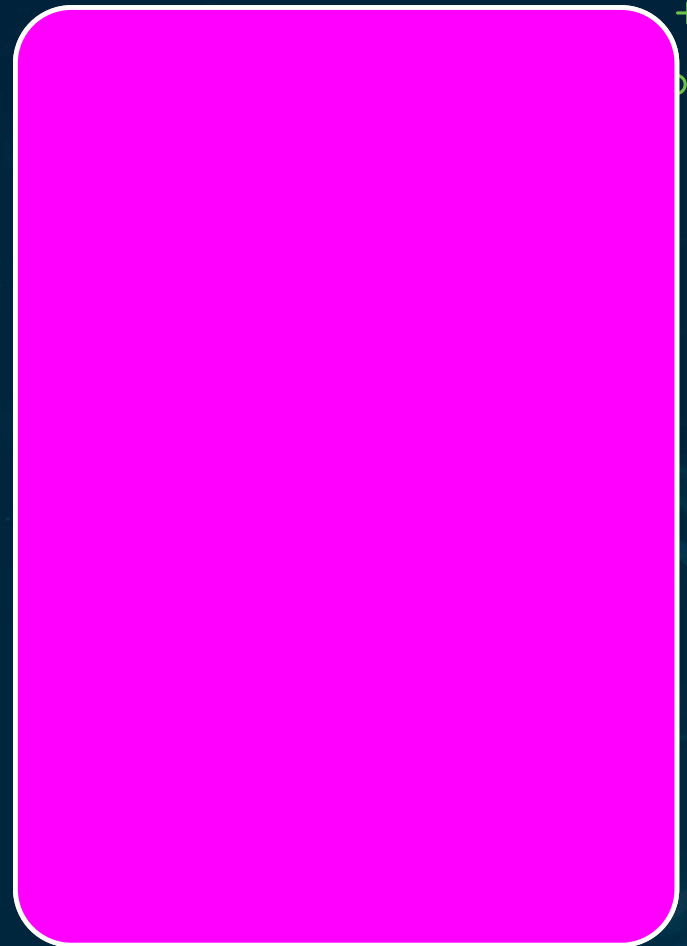


3 · Change Management

AI changes use the 8-step process

Significant changes feed the enterprise CAB

A subset of enterprise change management

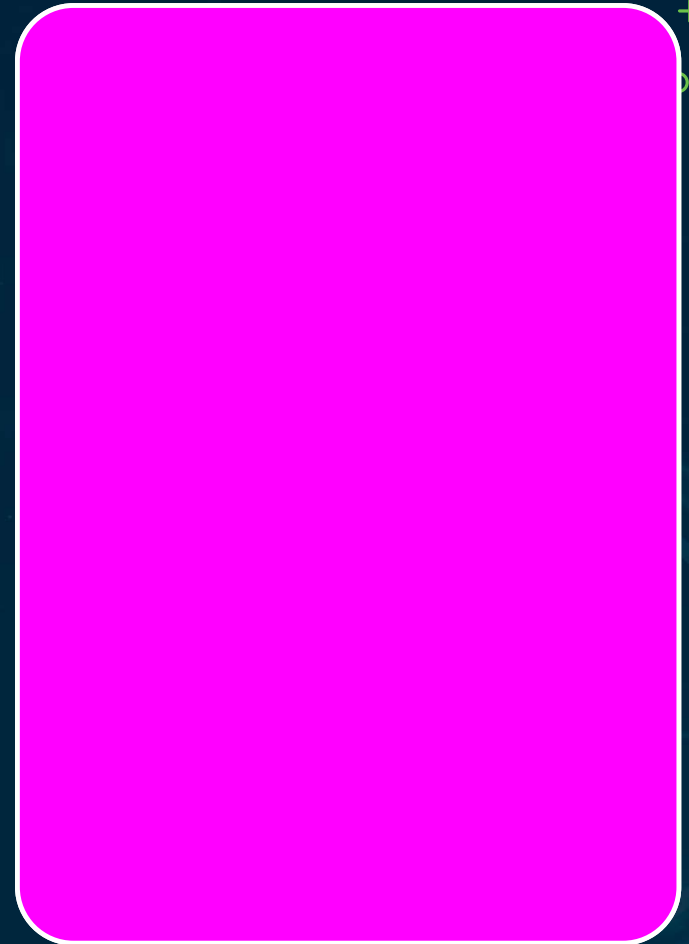


4 · Audit & Compliance

AI evidence in the enterprise audit package

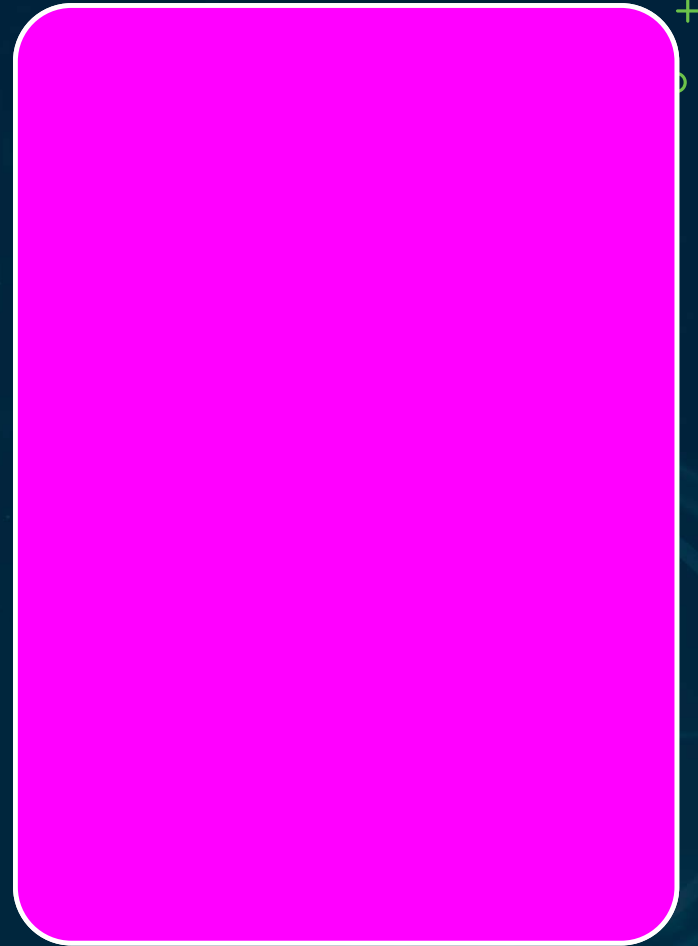
Framework alignment on the compliance calendar

Findings carry enterprise-level severity



5 · Security Operations

AI SIEM rules extend the enterprise SIEM
Inference · pipeline · registry logs feed it
AI engineer interfaces with the SOC



Four Alignment Failures



PARALLEL IR

AI IR runs beside enterprise IR



CAB BYPASS

Changes skip the enterprise CAB



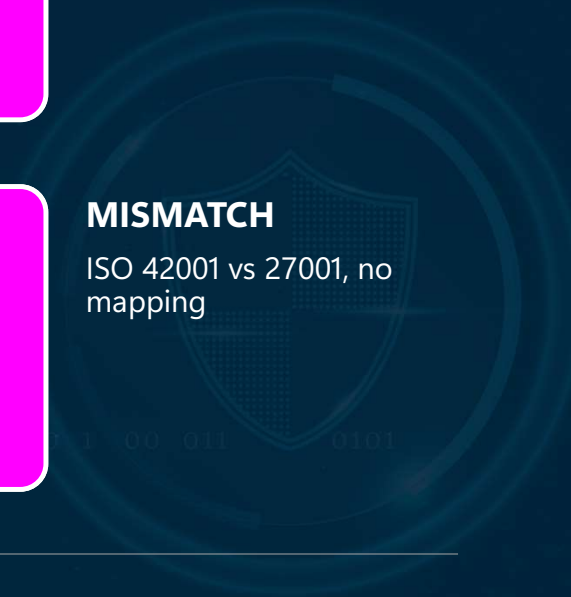
SILOED RISK

AI risks invisible to the CRO



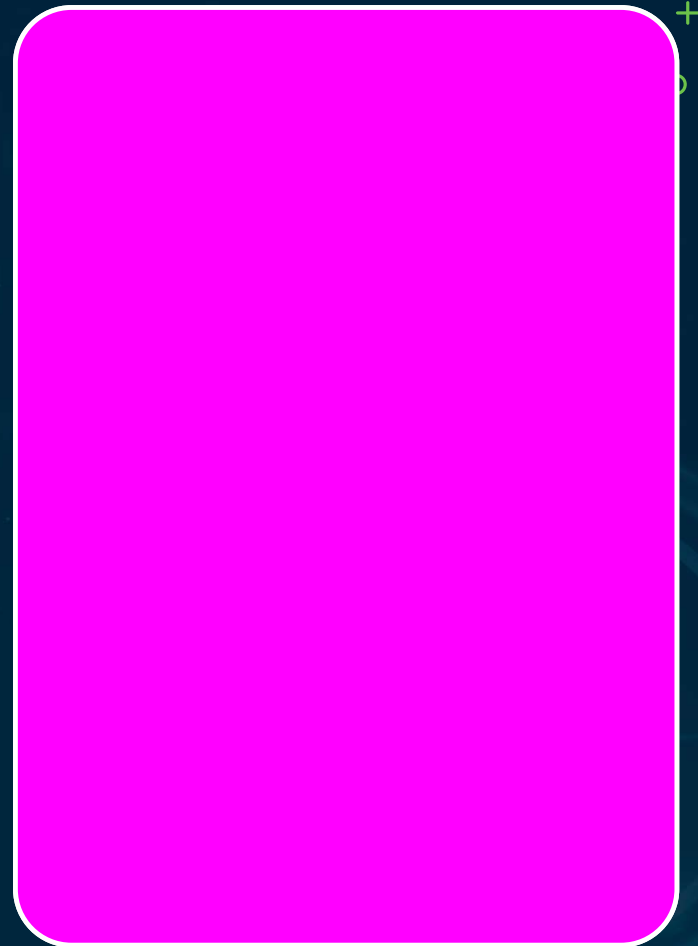
MISMATCH

ISO 42001 vs 27001, no mapping



The Fixes

IR integrated with enterprise IR
AI register feeds enterprise register
Material changes → enterprise CAB
Annual alignment review

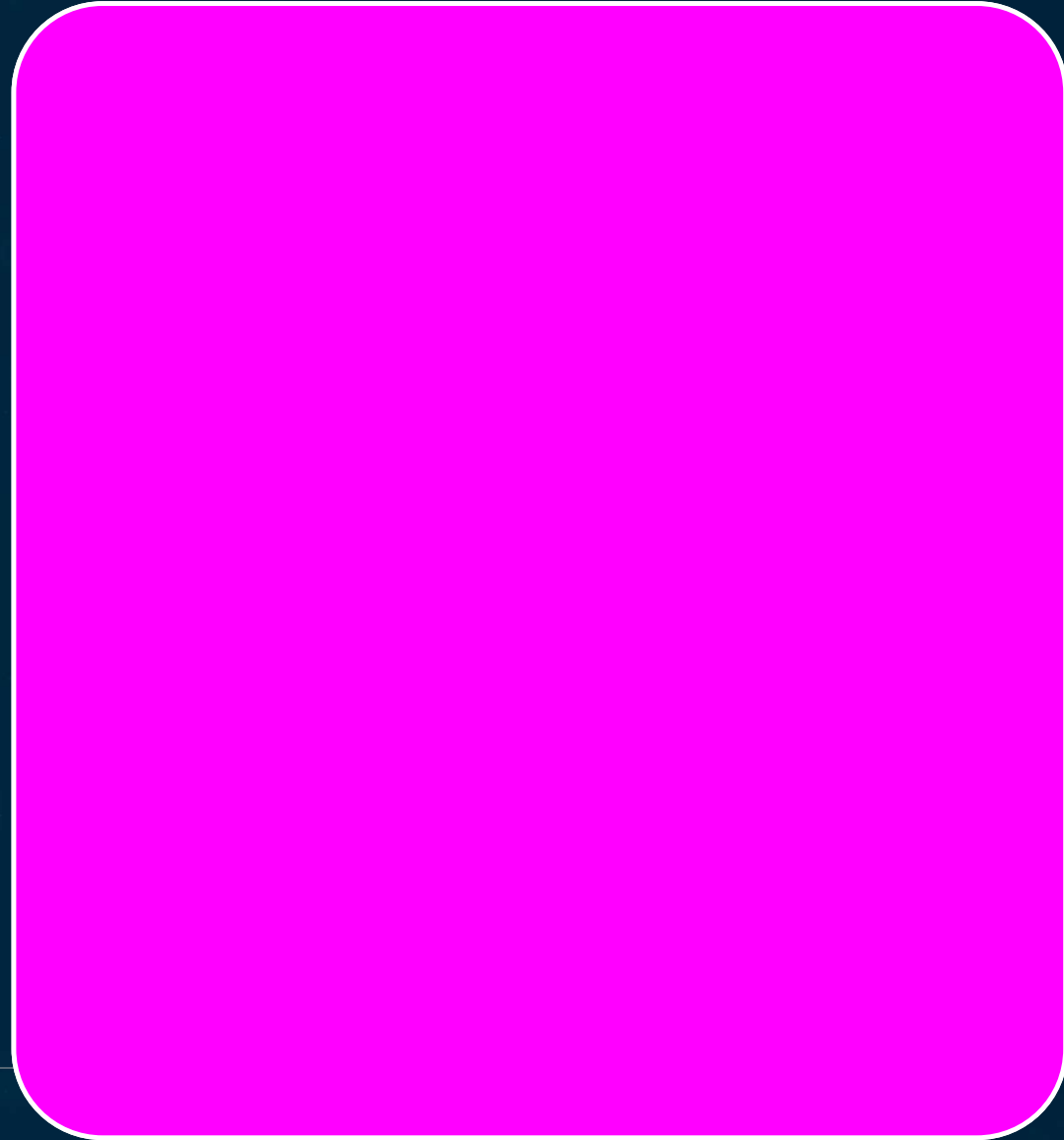


Alignment Is an Obligation

Each integration point has a named owner

Drift caught in annual alignment reviews

Alignment section = audit evidence



AI Security Team Structure & Proficiencies

Chapter 03 · Episode 4 — Dr. Michael Solomon



Four Core Roles



SECURITY LEAD

Owns program · L3+ escalations



SEC ENGINEER

SIEM · detection · vuln mgmt



COMPLIANCE

Inventory · licenses · DPIA



RISK ANALYST

Risk register · V&V cycle



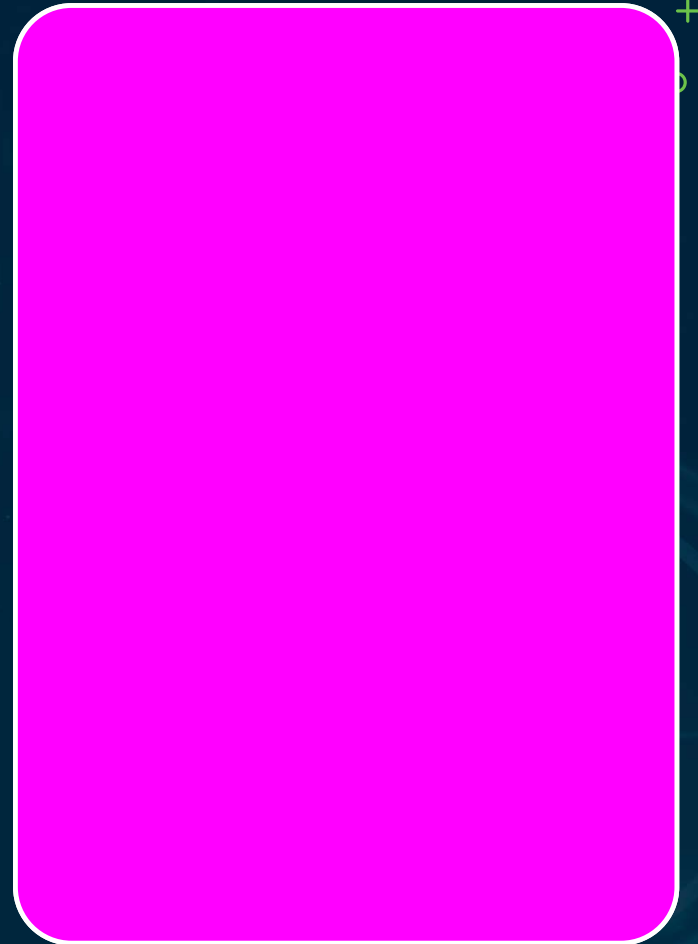
Proficiency Requirements

Lead: AI/ML + governance frameworks

Assess model claims, not build models

All roles: EU AI Act · GDPR 22 · AI RMF

Lead accountable; team responsible



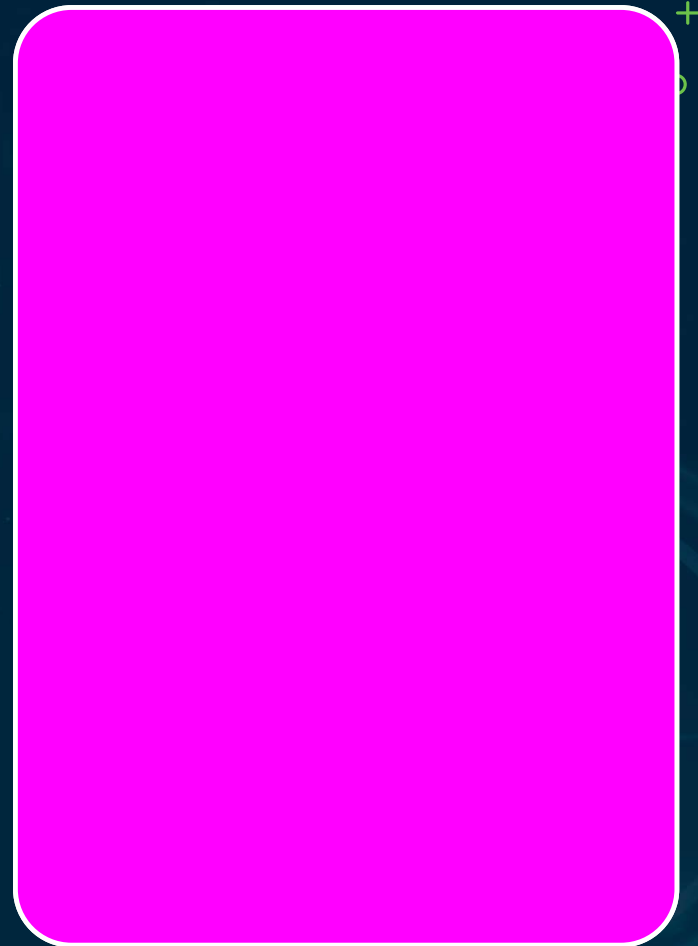
Reporting Lines & Independence

Lead reports to CISO, not the AI team

Governance independent of development

If not fully: conflict-of-interest controls

Independence is structural



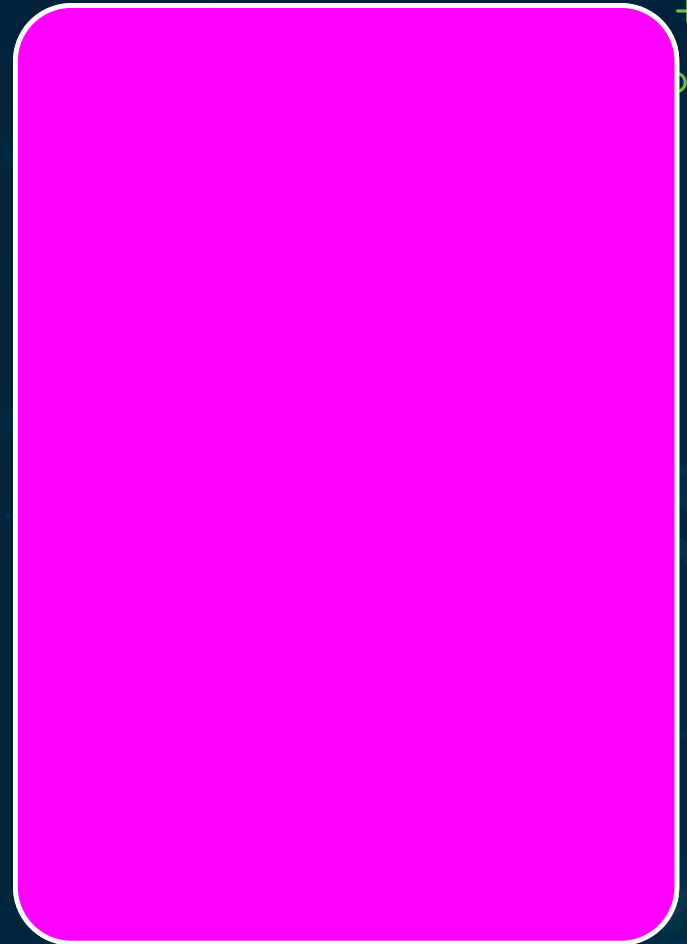
RACI for Key Activities

Lead = A for all governance activities

Compliance = R: inventory · licenses · DPIA

Engineer = R: monitoring · SIEM · vulns

Risk analyst = R: register · V&V



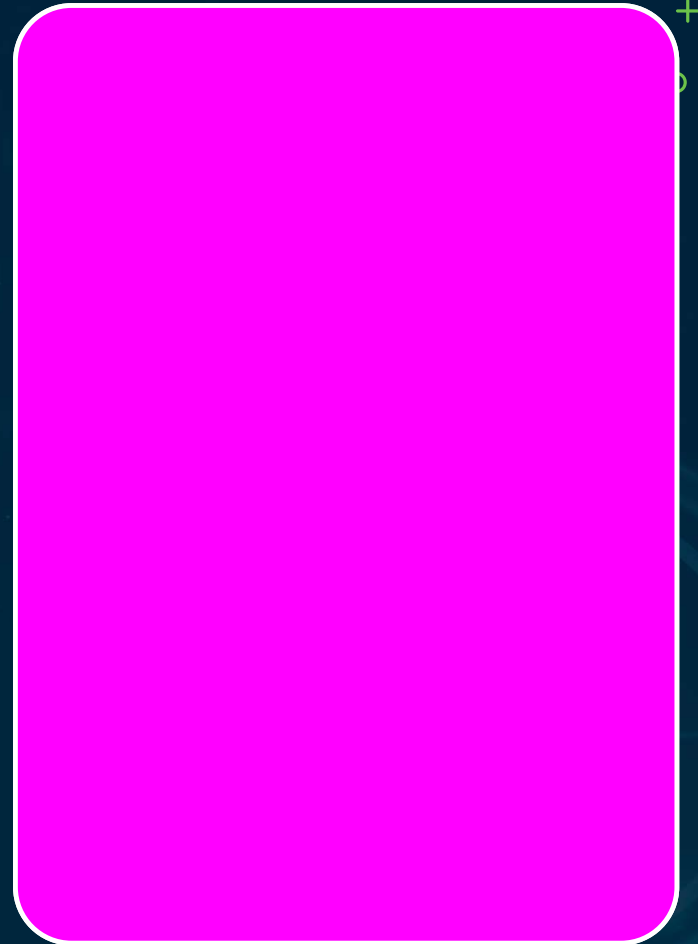
Team Size & Scaling

Min viable tier-1: 2 FTE (lead + analyst)

Coverage gaps = accepted register risks

Consultants OK — the lead stays internal

Accountable role cannot be outsourced

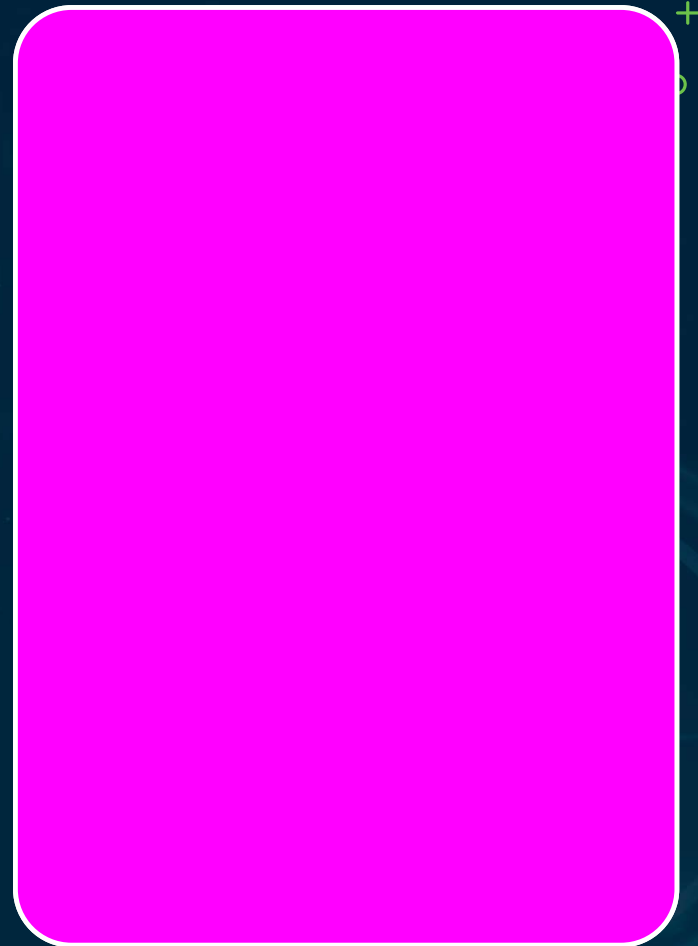


Competency Framework

Documented competencies + dev plan

Annual competency review

A program-plan requirement, not just HR



Four Structure Failures



LOST INDEPENDENCE

Lead reports into AI development



HIDDEN GAPS

Competency gaps undocumented



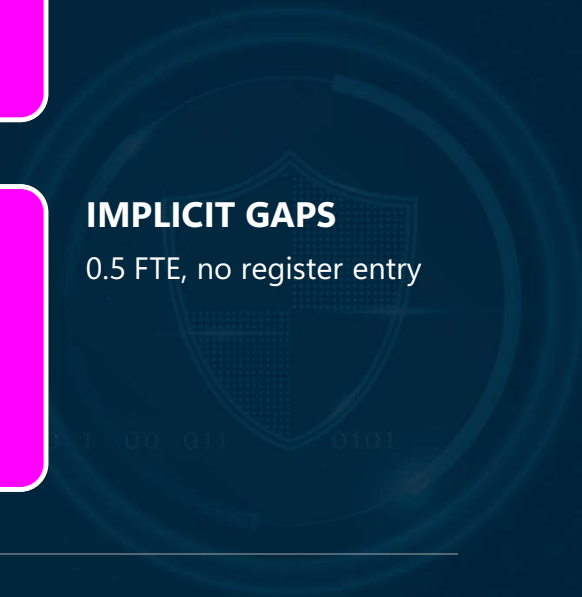
OUTSOURCED A

Accountable role to a consultant



IMPLICIT GAPS

0.5 FTE, no register entry



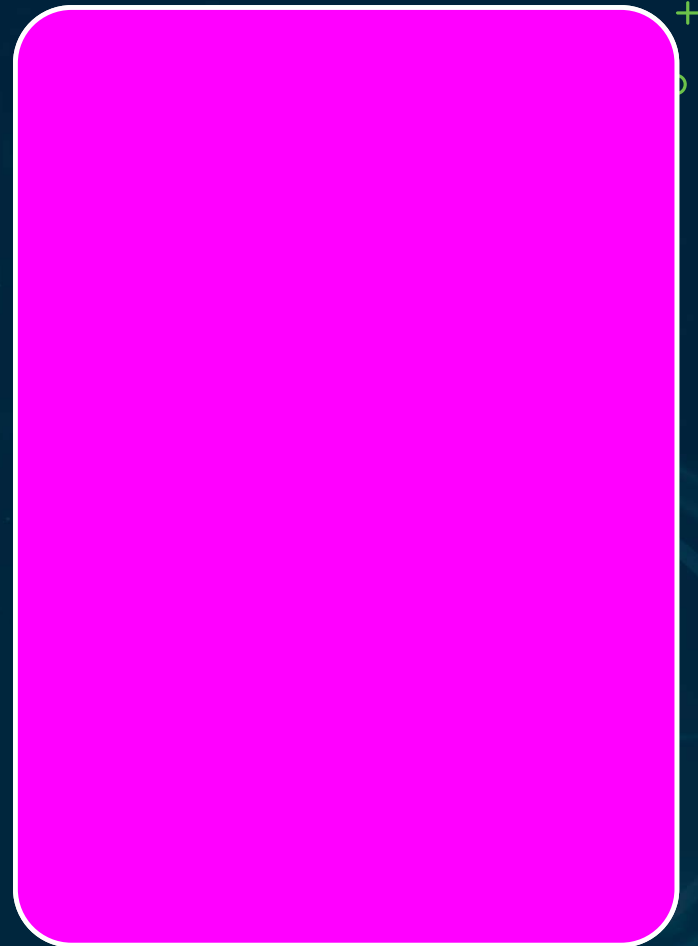
The Fixes

Lead reports to CISO, not development

Accountable roles stay internal

Document + address competency gaps

Coverage gaps become register entries



Structure = Program Plan

Roles align to the governance RACI

Role gaps = control gaps on the register

Team structure reviewed annually

AI-Enabled Security Tools in the Program

Chapter 03 · Episode 5 — Dr. Michael Solomon

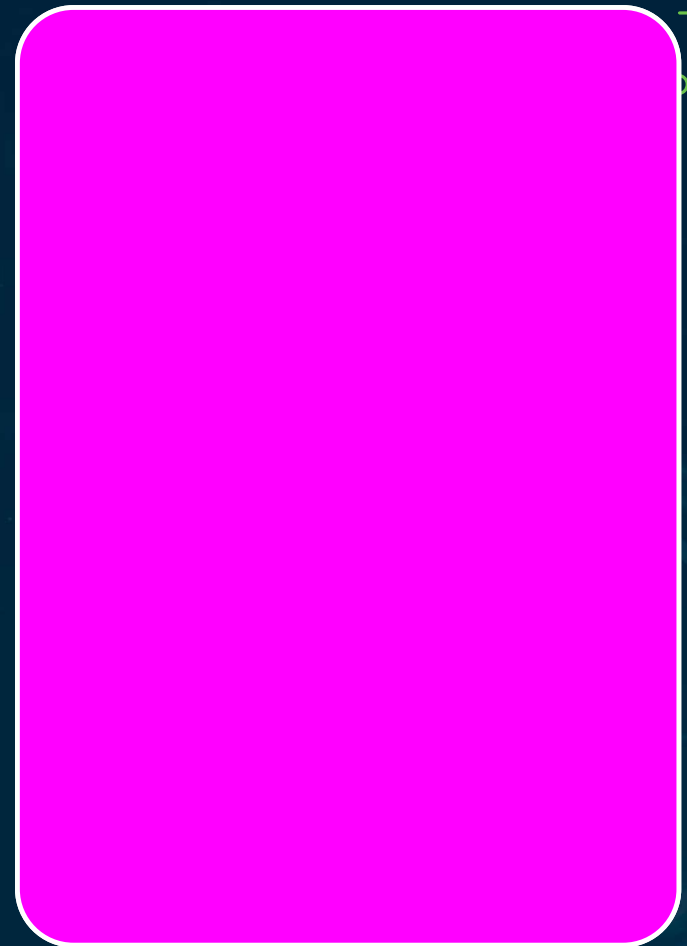


The SOC Scale Problem

Threat volume outpaces analyst capacity

Log data multiplies faster than human review

AI processes telemetry + correlates + accelerates

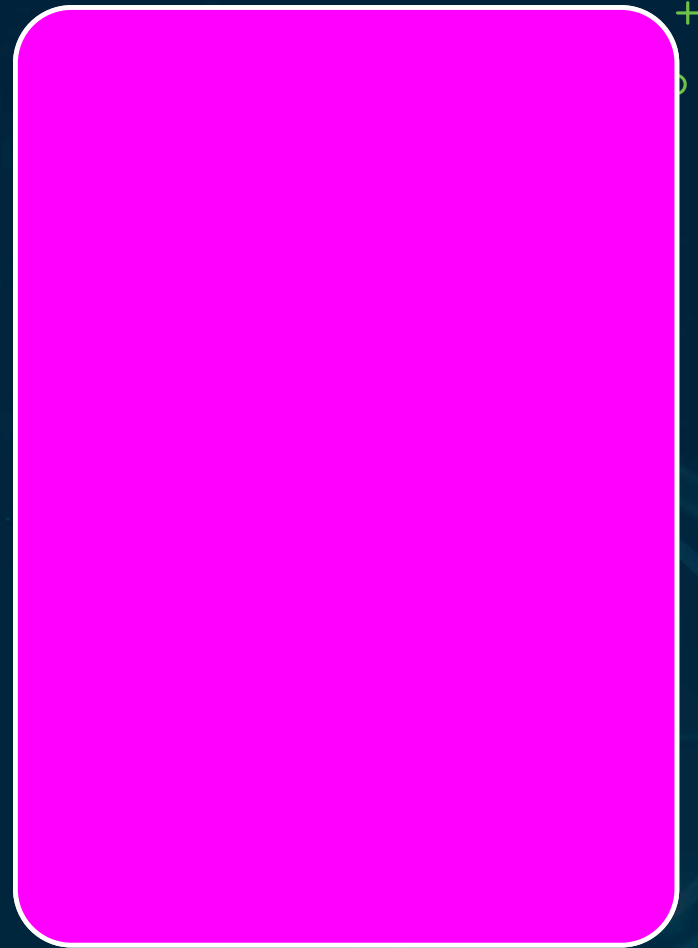


AI Augments, Doesn't Replace

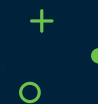
AI handles volume; analysts apply judgment

Faster, more accurate security operations

Identify tools by category, function, risk



AI-Augmented Analyst Workflow



Detection

ML anomaly detection
cuts dwell time

Triage

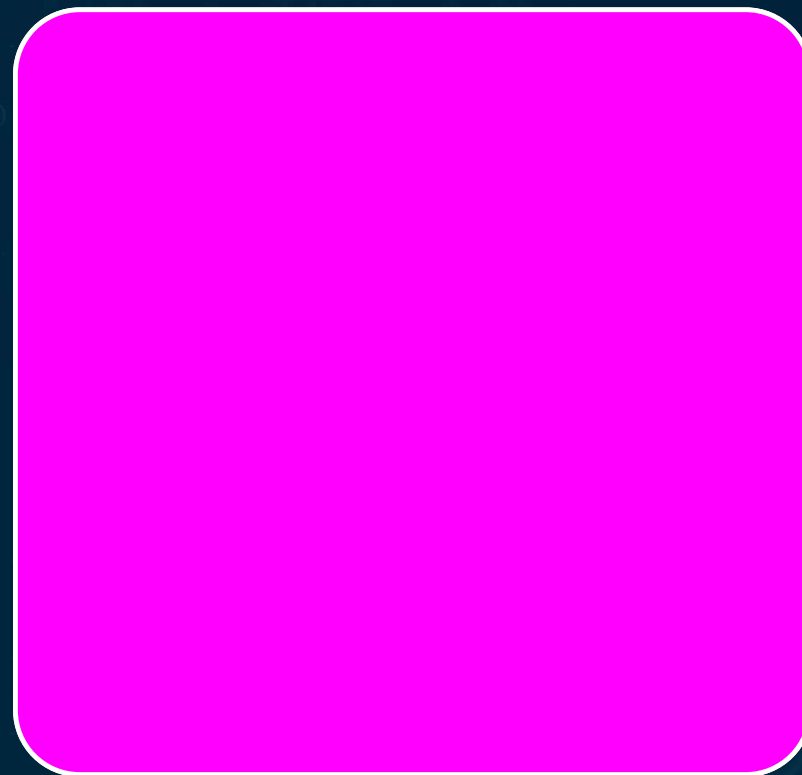
Score, correlate, suppress
noise

Investigation

Auto-enrich; query TI in
seconds

Response

Accelerated across the
lifecycle



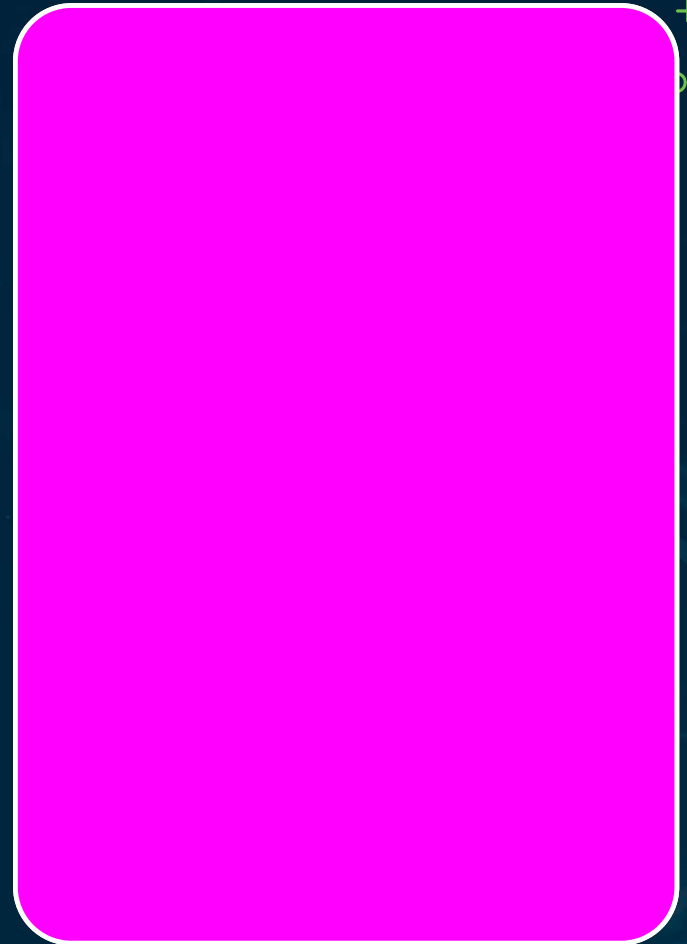
Threat-Intelligence Tools

AI-specific feeds: MITRE ATLAS, AI Incident Database

CVE alerts for AI components required

Feeds the monitoring-calendar review

Strategic TI triggers threat-model updates

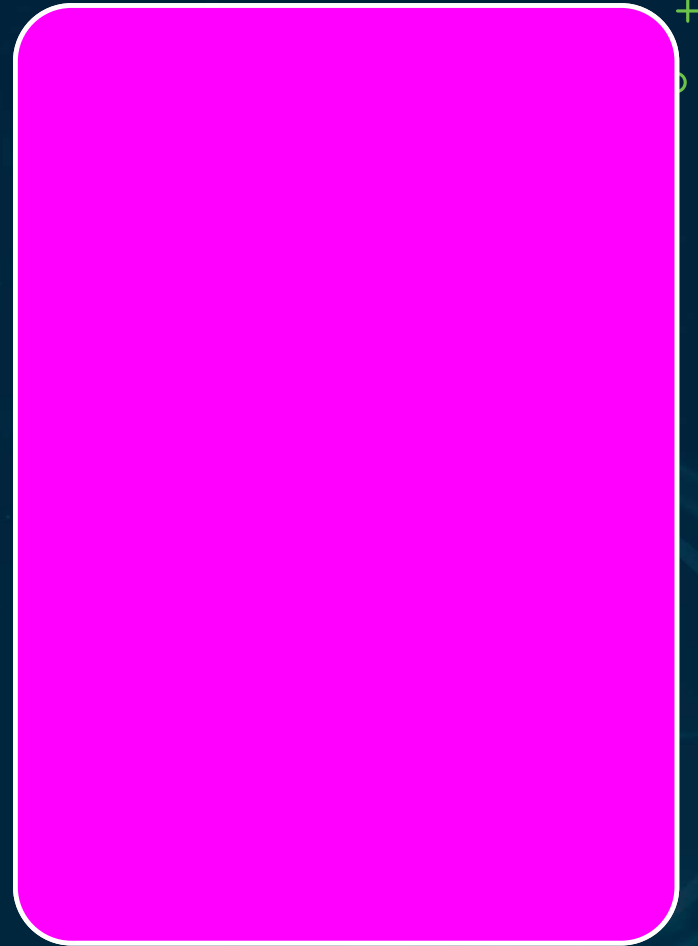


AI Vulnerability Analysis

Thousands of findings per scan cycle

AI ranks by exploitability, context, adversary interest

Surfaces the urgent few from the many



Three Vuln-Analysis Capabilities



Pattern Recognition

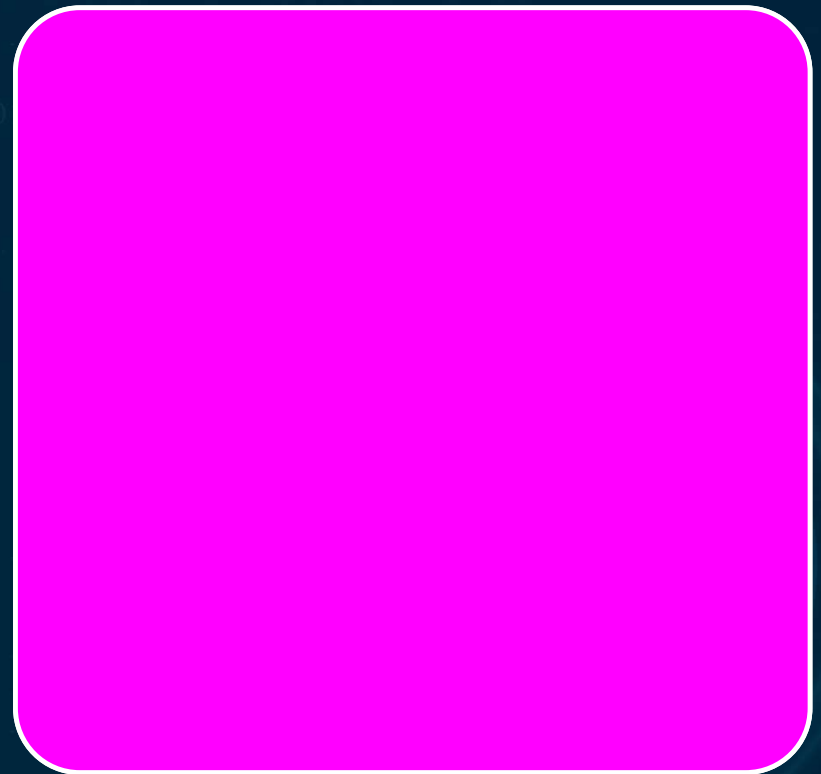
Static + dynamic analysis of code/behavior

Prioritization

Multi-dimensional, context-aware ranking

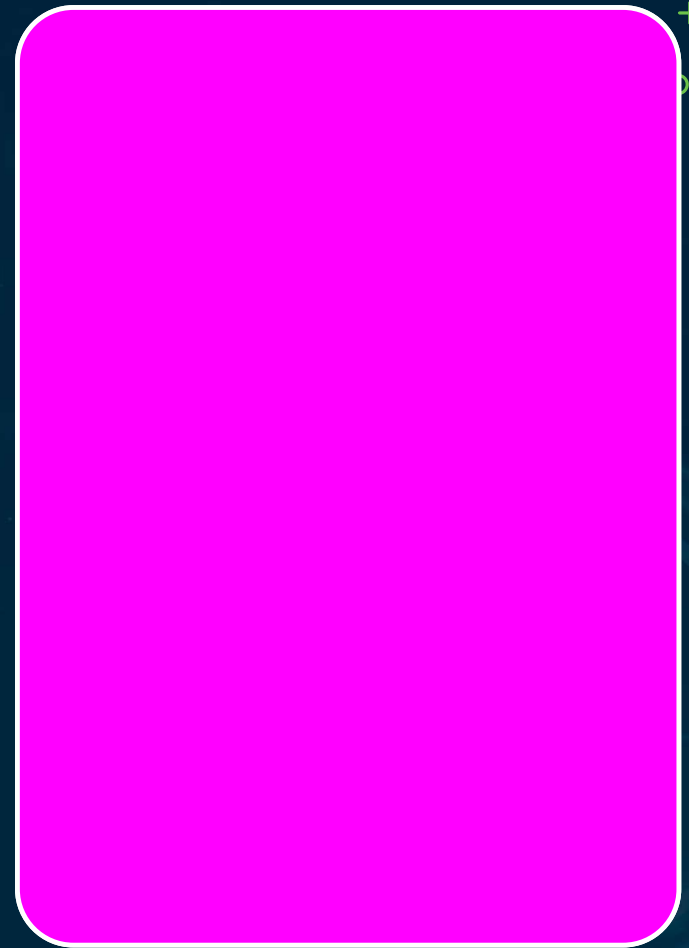
Anomaly Detection

Drift from baselines; no signature needed

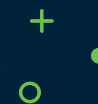


Governance Requirements

Continuous model updates + retraining schedules
Human validation workflows (false-positive mgmt)
Asset-inventory integration for context
Distinguishes mature programs from ad-hoc scanning



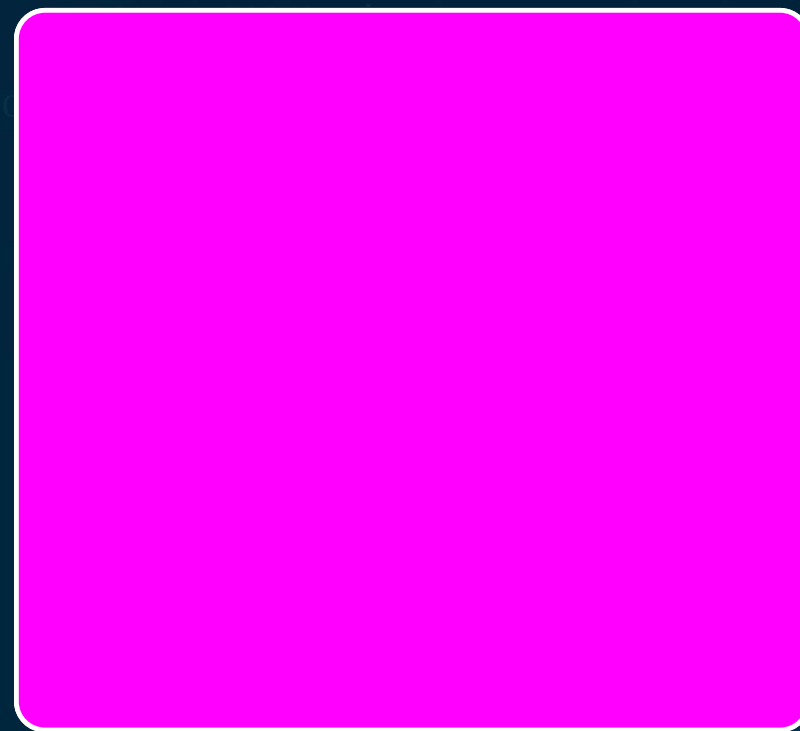
SECURITY AI TOOLS ARE AI SYSTEMS



They require asset-inventory registration + governance

Same intake track as operational AI

UEBA, TI, SIEM-ML all subject to it



AI Security Metrics: KPIs & KRIs

Chapter 03 · Episode 6 — Dr. Michael Solomon



KPI vs KRI

KPI

Measures control performance

"Is the control working?"

KRI

Measures residual-risk exposure

Both required per control



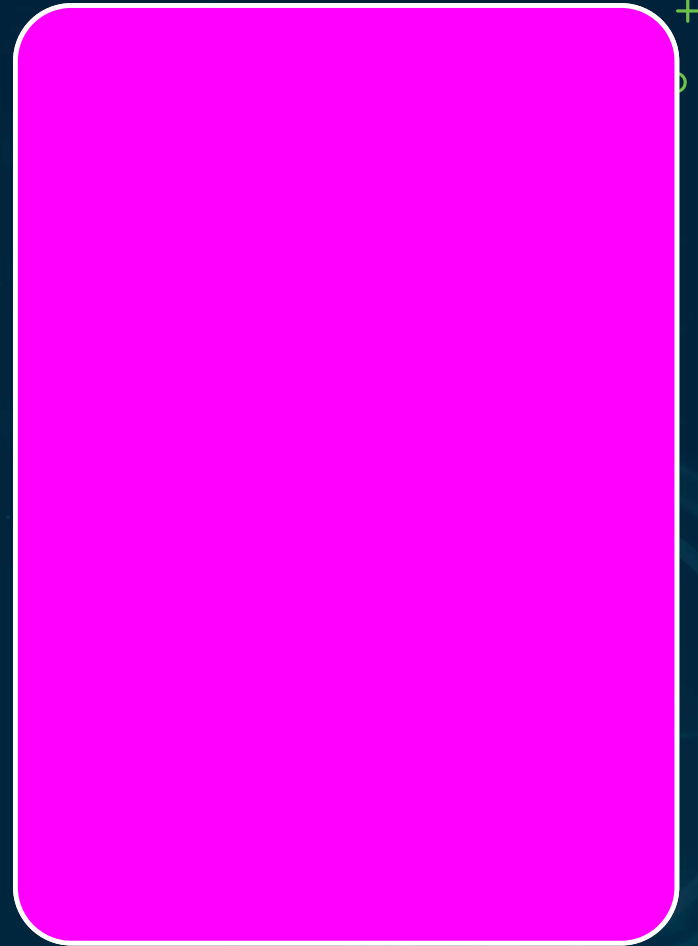
KPI Design

Name · method · target · cadence · owner

e.g. 99%+ AI decisions fully logged

Below threshold → L2+ finding

No KPI = nominal, not operational



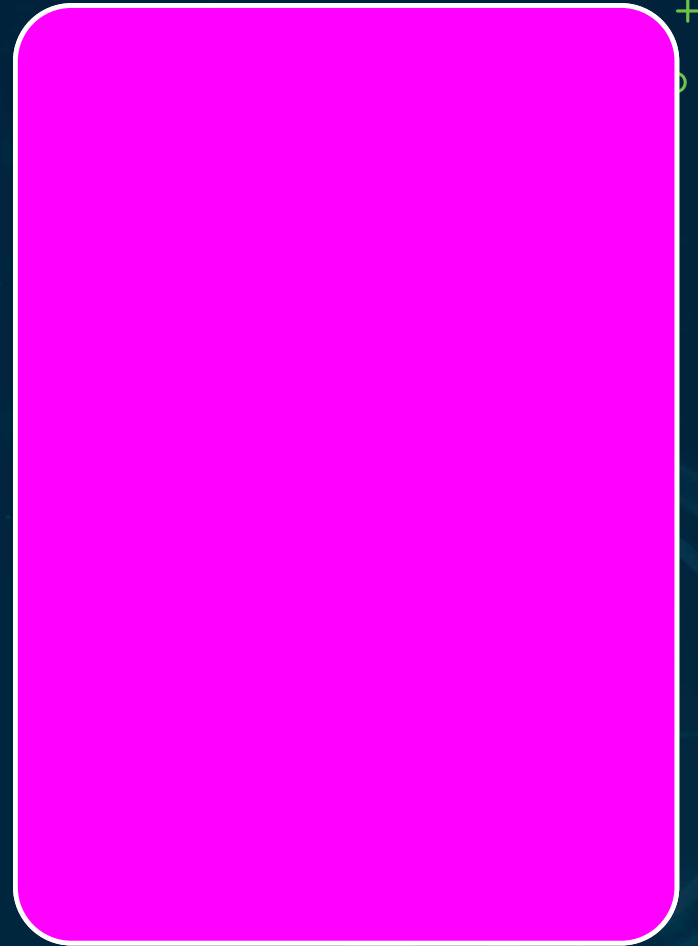
KRI Design

Residual risk after the control operates

A threshold triggers escalation

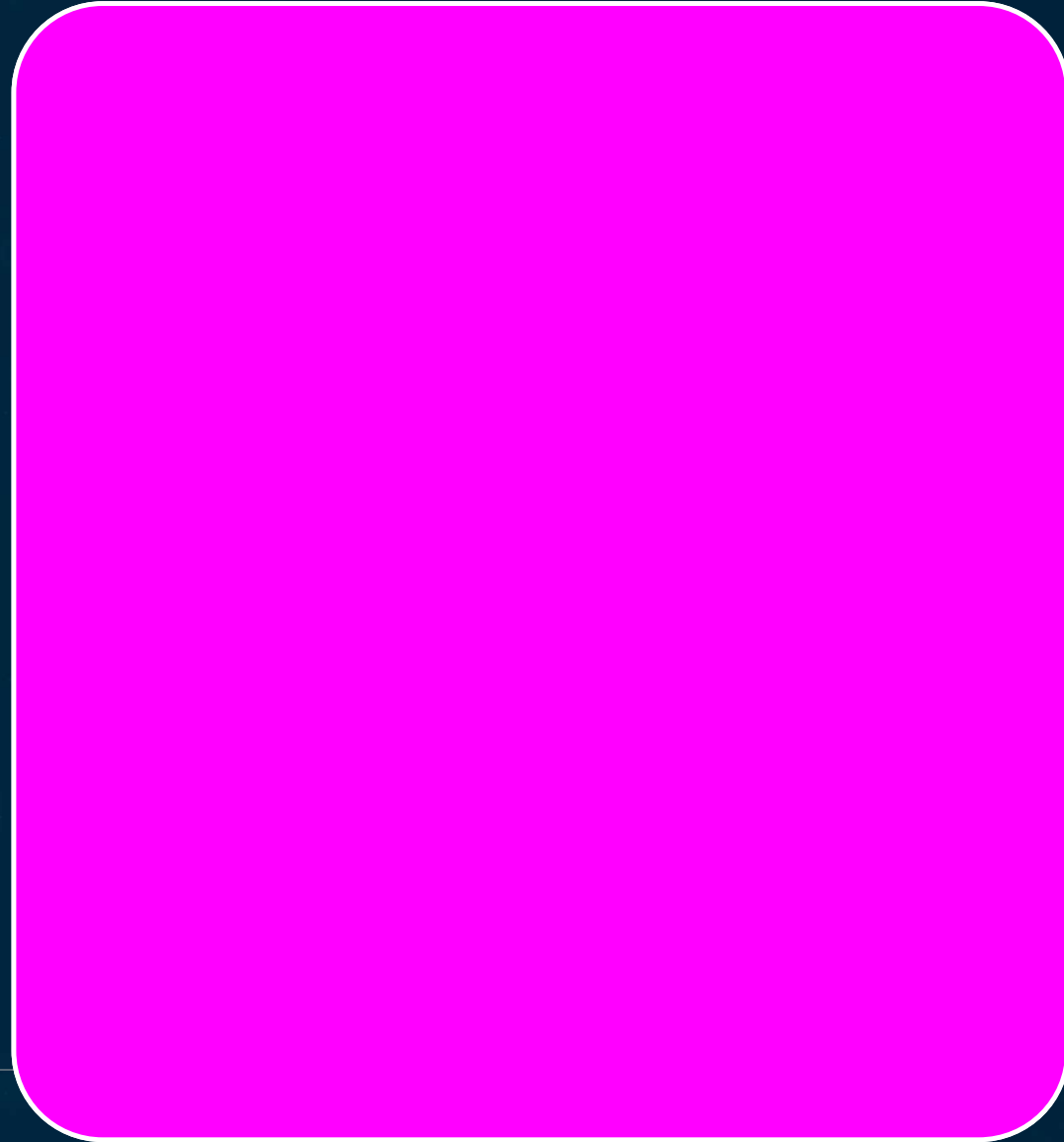
e.g. injection attempts detected-not-blocked

Primary input to the risk register



Module-Level Dashboard

Integrates KPIs from all six modules
Governance · data · incident · controls
One monitoring dashboard



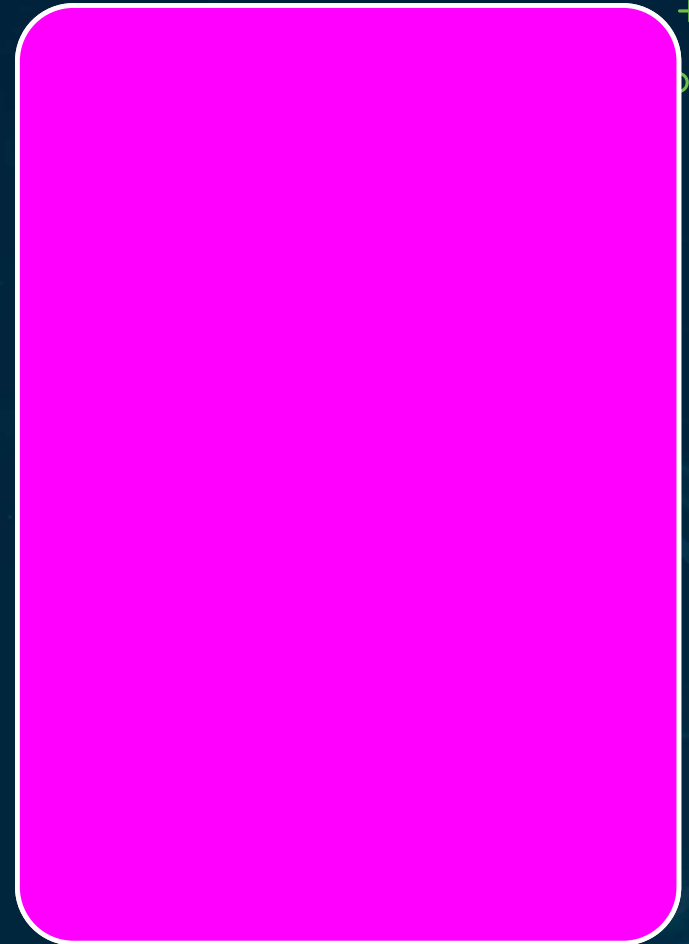
Three Reporting Levels

Operational — monthly

Steering — quarterly

Board — annual

L4/L5 → out-of-cycle exec report



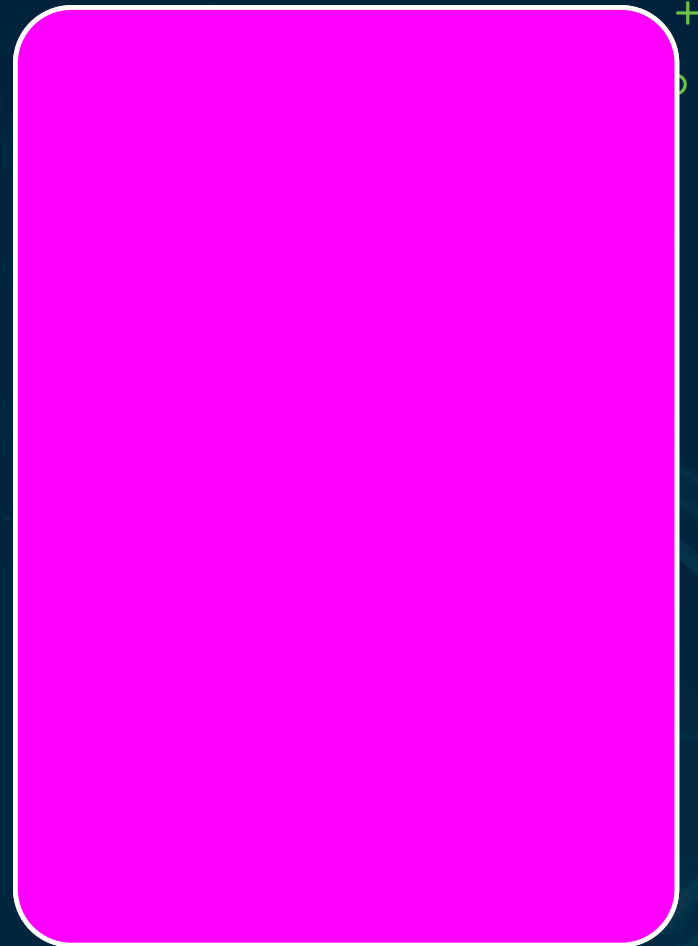
Baselines

Every KPI needs a deployment baseline

Calibrate thresholds to the baseline

Review after 30–60 days of data

Baseline before claiming it works

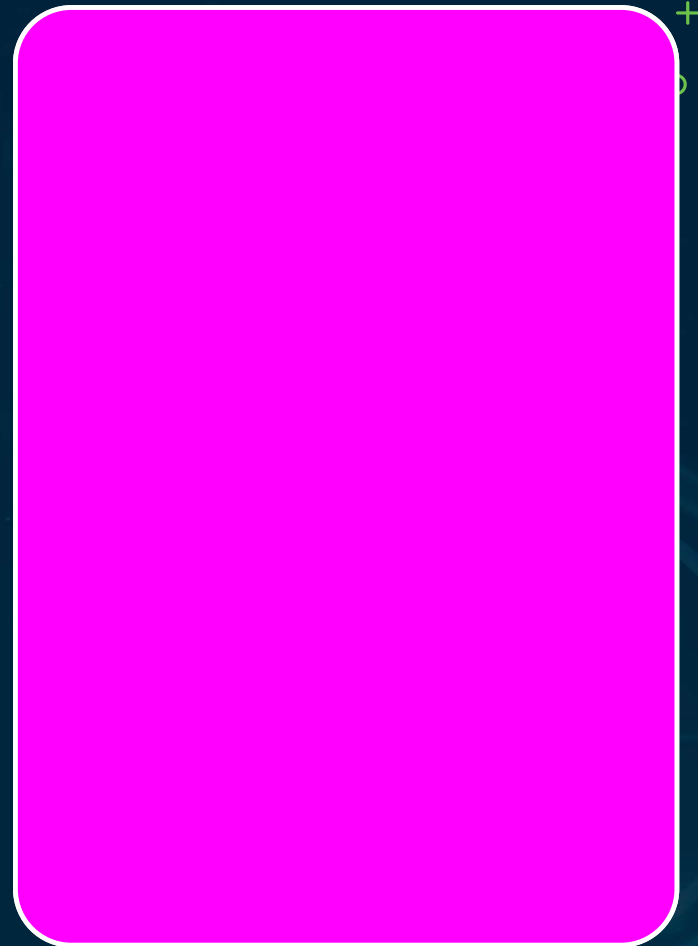


Metrics = Program Plan

Framework documented in the program plan

Controls without KPIs/KRIs = register gaps

Reviewed annually + on material change



Four Metrics Failures



NO KPIs

12 controls, none demonstrable



NO BASELINE

Can't tell normal from degraded



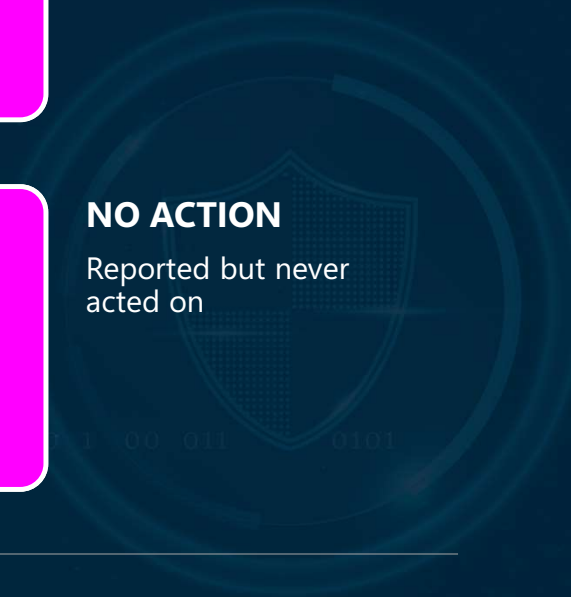
NO THRESHOLDS

KRIs breach with no trigger



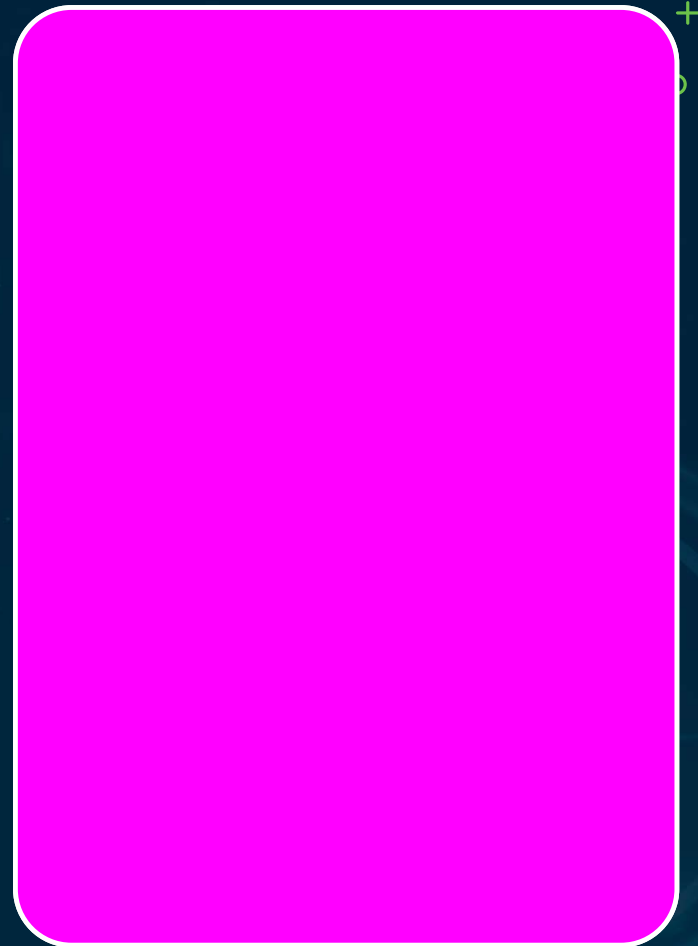
NO ACTION

Reported but never acted on



The Fixes

- KPI per control before deployment
- Explicit KRI thresholds
- Baselines measured + reviewed
- Breaches trigger documented responses



Recap

KPI = performance · KRI = residual risk

Both required per control

Baseline is always required

AI Security Metrics: KPIs & KRIs

Chapter 03 · Episode 6 — Dr. Michael Solomon



KPI vs KRI

KPI

Measures control performance

"Is the control working?"

KRI

Measures residual-risk exposure

Both required per control



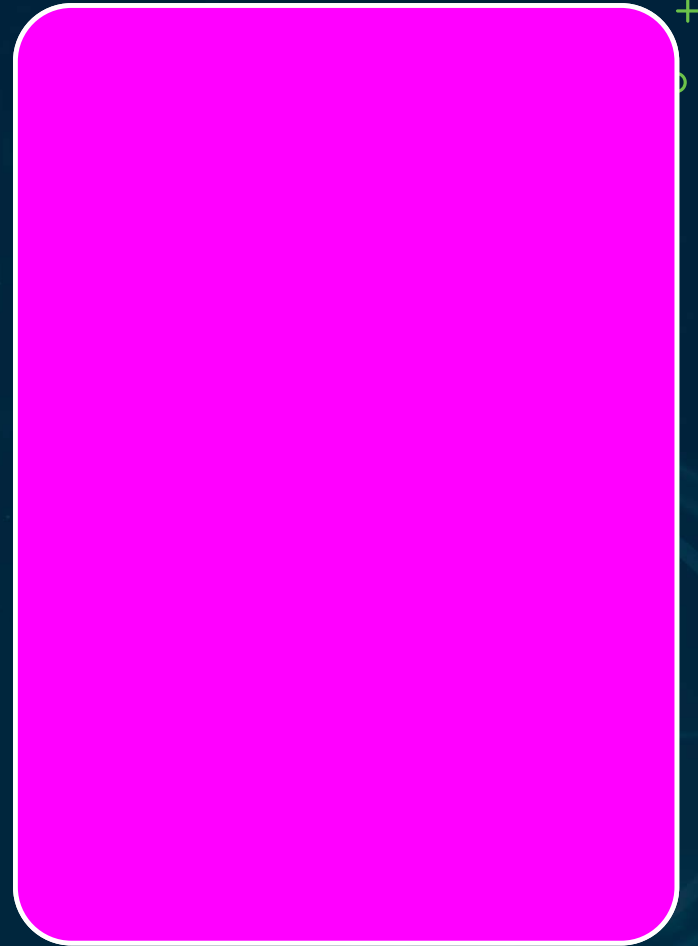
KPI Design

Name · method · target · cadence · owner

e.g. 99%+ AI decisions fully logged

Below threshold → L2+ finding

No KPI = nominal, not operational



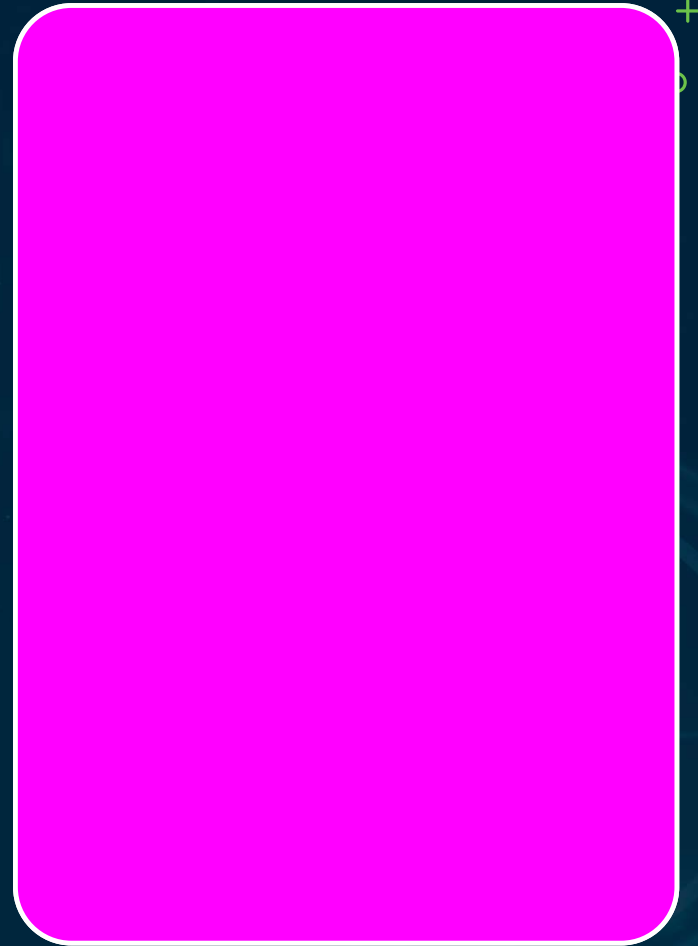
KRI Design

Residual risk after the control operates

A threshold triggers escalation

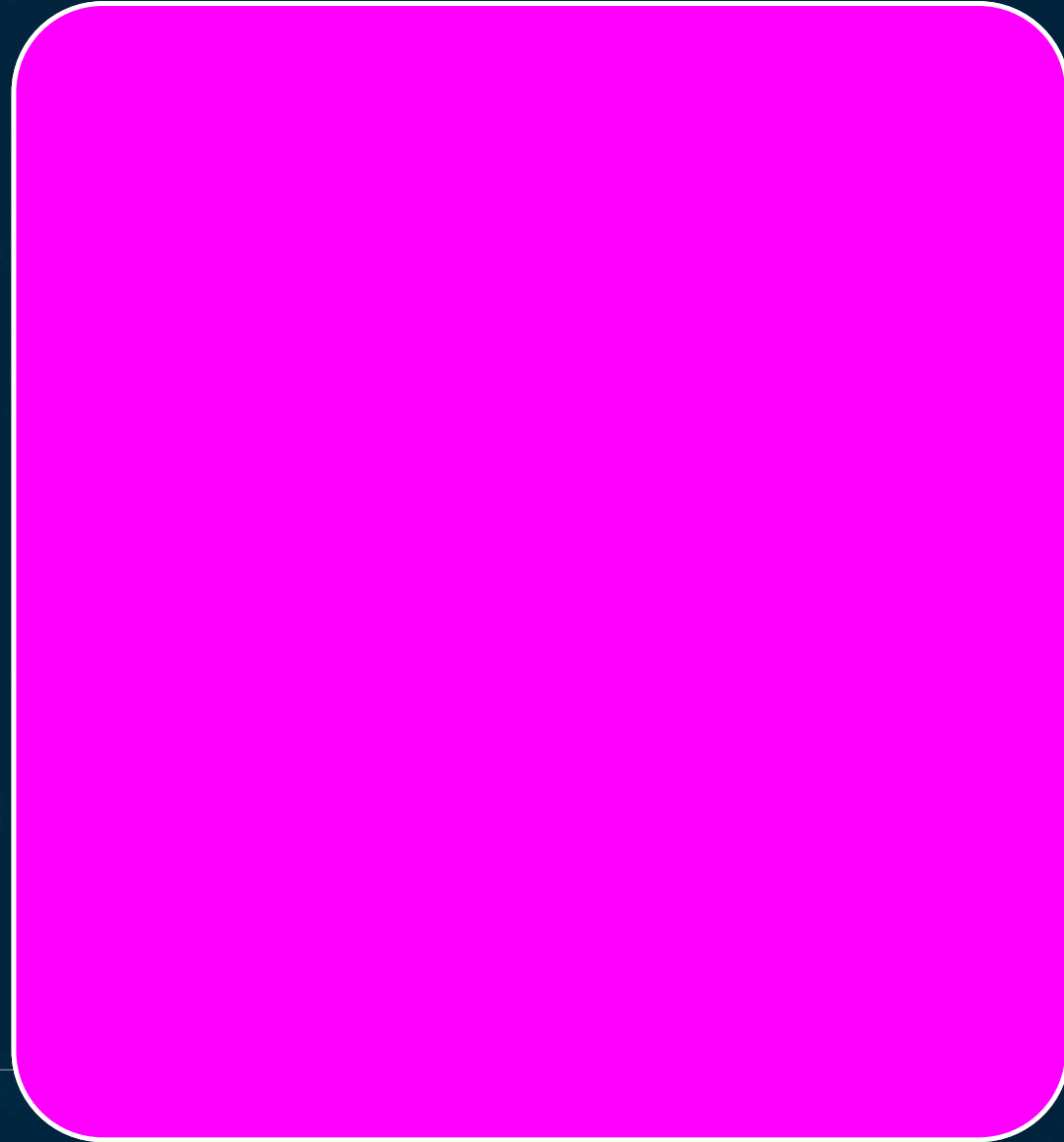
e.g. injection attempts detected-not-blocked

Primary input to the risk register



Module-Level Dashboard

Integrates KPIs from all six modules
Governance · data · incident · controls
One monitoring dashboard



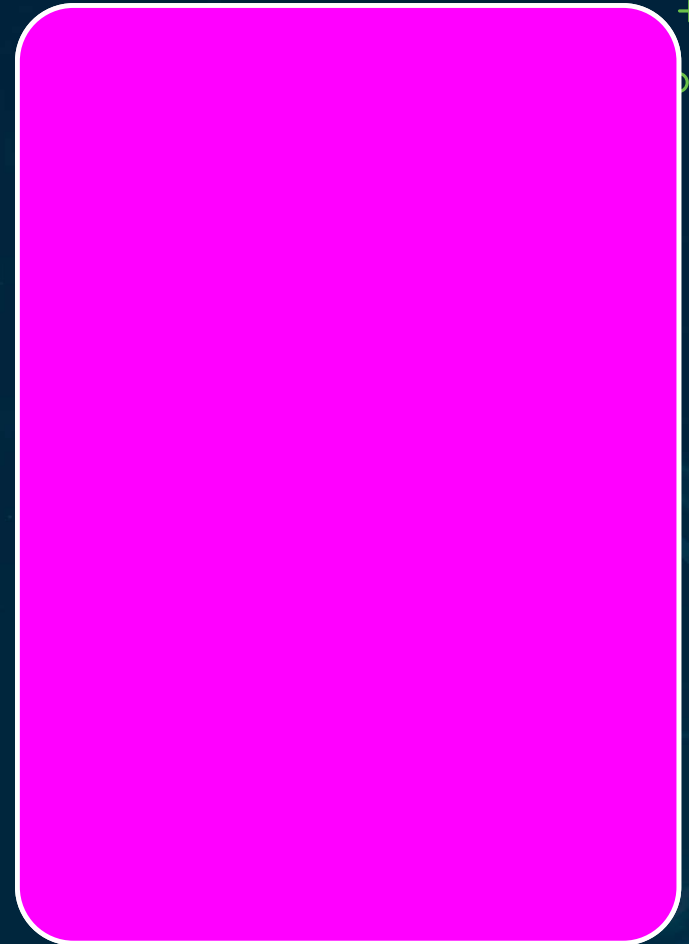
Three Reporting Levels

Operational — monthly

Steering — quarterly

Board — annual

L4/L5 → out-of-cycle exec report



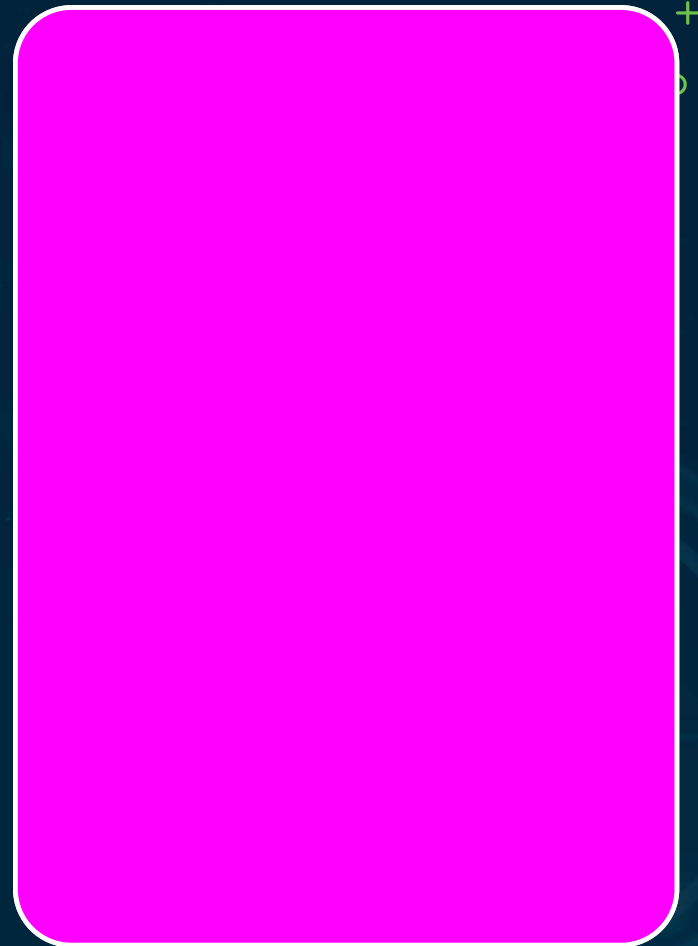
Baselines

Every KPI needs a deployment baseline

Calibrate thresholds to the baseline

Review after 30–60 days of data

Baseline before claiming it works

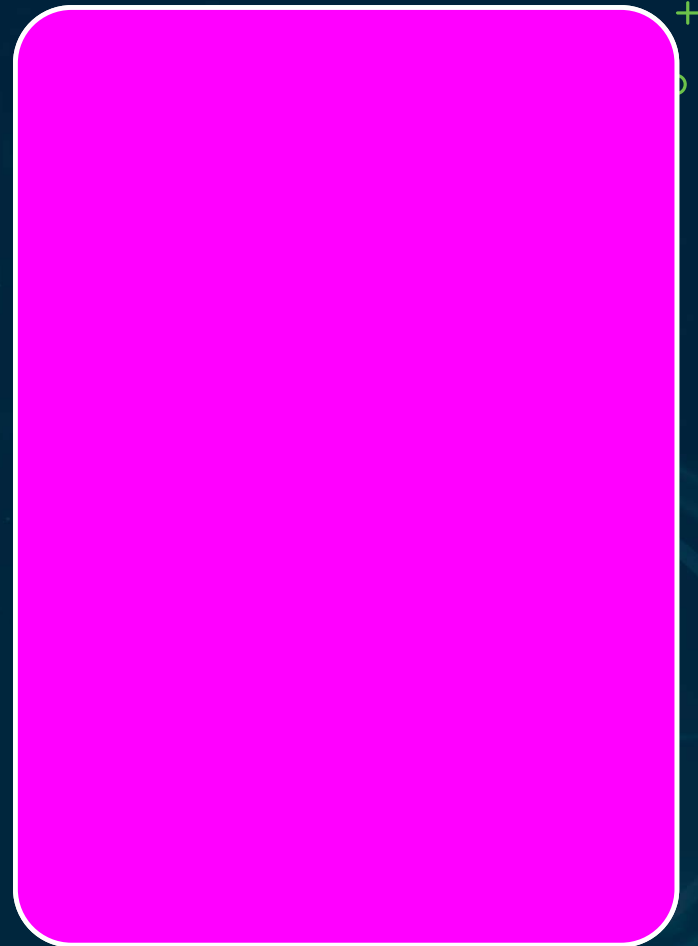


Metrics = Program Plan

Framework documented in the program plan

Controls without KPIs/KRIs = register gaps

Reviewed annually + on material change



Four Metrics Failures



NO KPIs

12 controls, none demonstrable



NO BASELINE

Can't tell normal from degraded



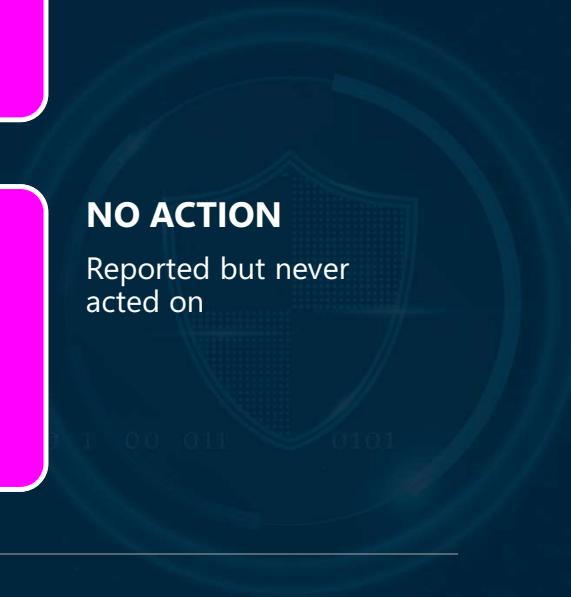
NO THRESHOLDS

KRIs breach with no trigger



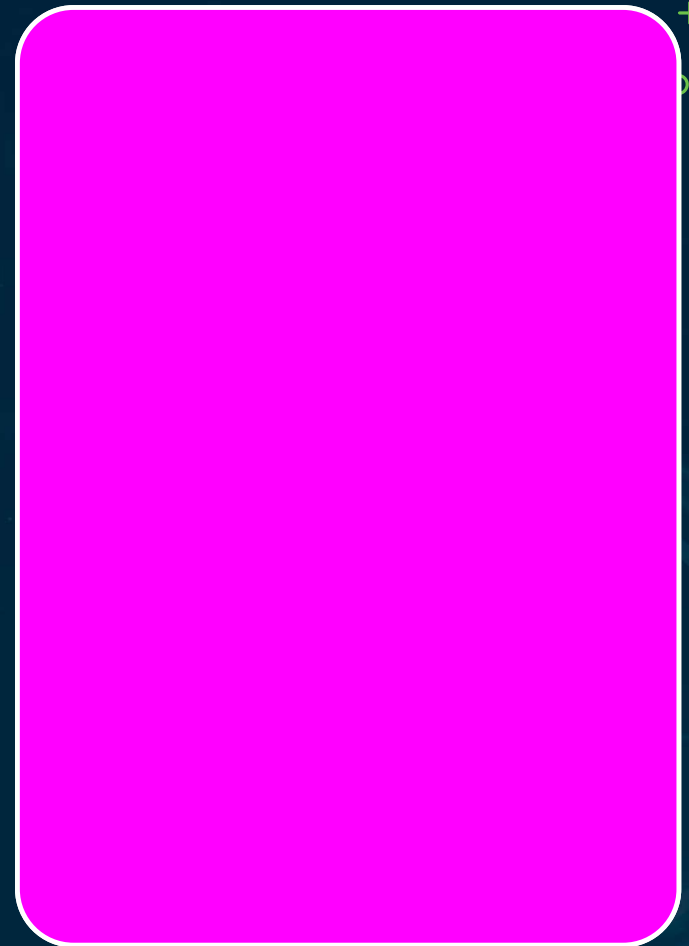
NO ACTION

Reported but never acted on



The Fixes

- KPI per control before deployment
- Explicit KRI thresholds
- Baselines measured + reviewed
- Breaches trigger documented responses



Recap

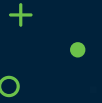
KPI = performance · KRI = residual risk

Both required per control

Baseline is always required

Executive & Management Reporting

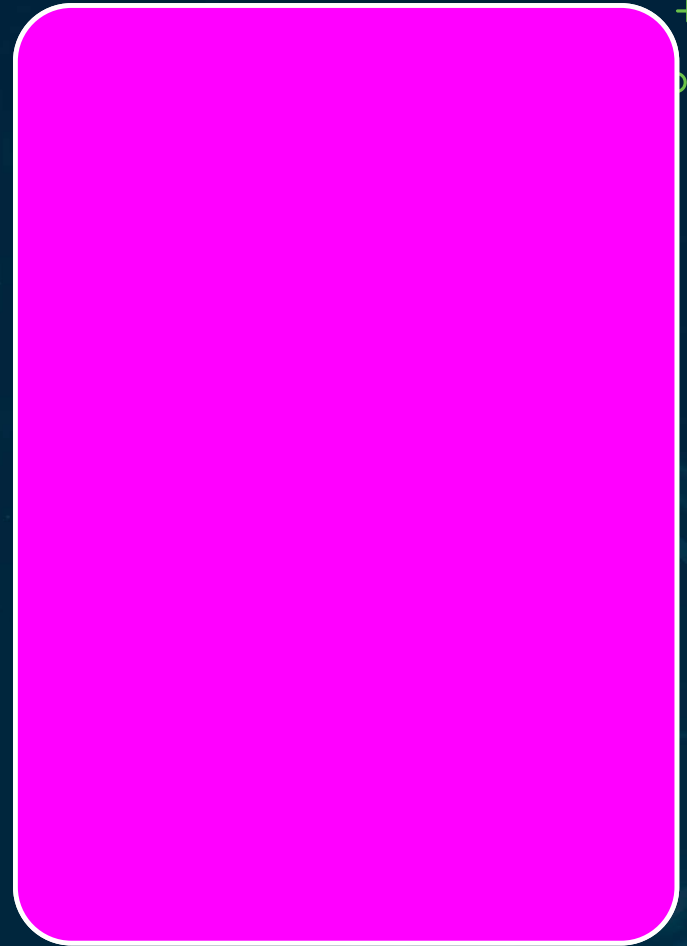
Chapter 03 · Episode 7 — Dr. Michael Solomon

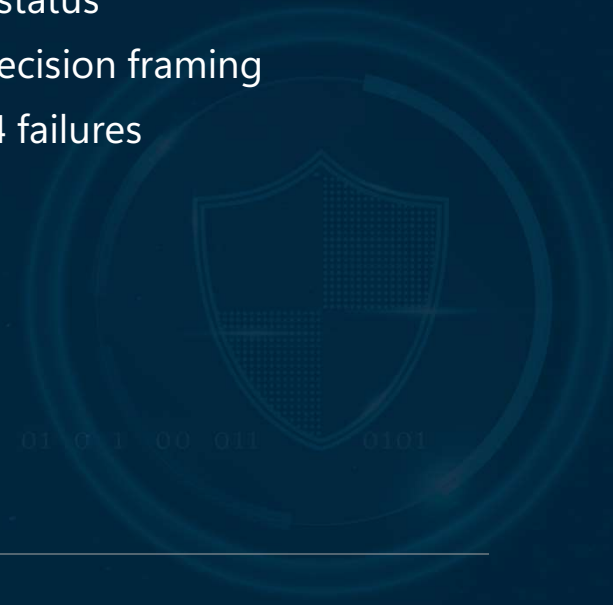
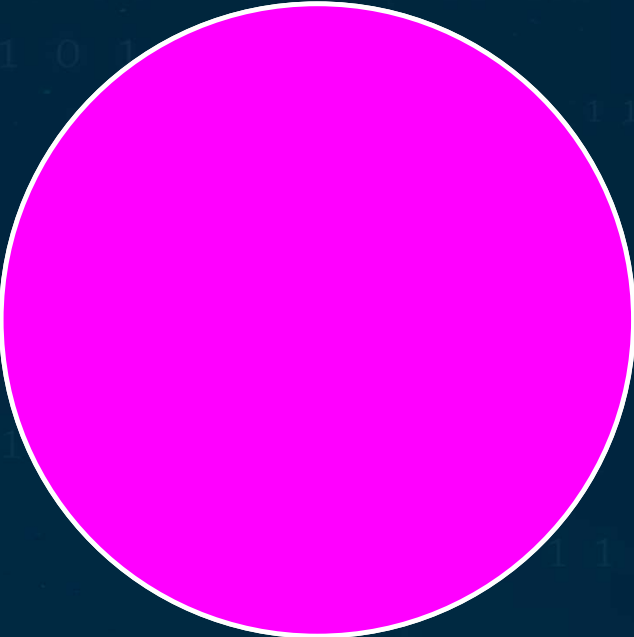


Two Failure Modes

Rubber-stamp approval

Disengagement





What This Episode Covers

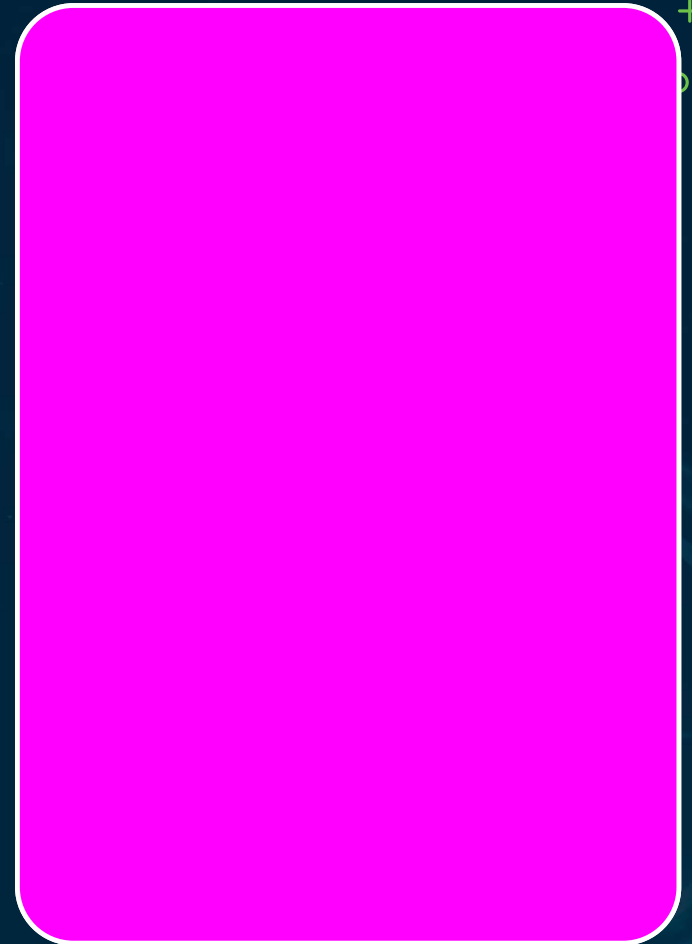
1. 5-section report · RAG status
2. Business translation · decision framing
3. Annual board report · 4 failures

Three Reporting Tiers

Operational — monthly (security lead)

Steering — quarterly (committee)

Board — annual

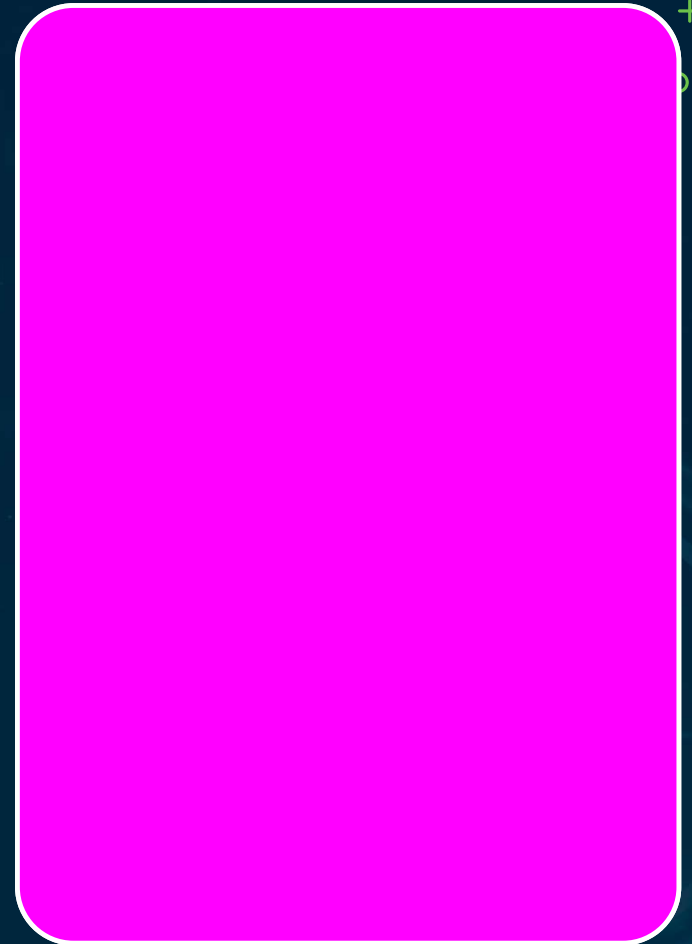


What Each Tier Contains

Monthly: KPI/CRI + L3+ findings

Quarterly: risk register, vendors, incidents

Annual: appetite, maturity, compliance



Board Report Content



1

Appetite vs
actual posture

2

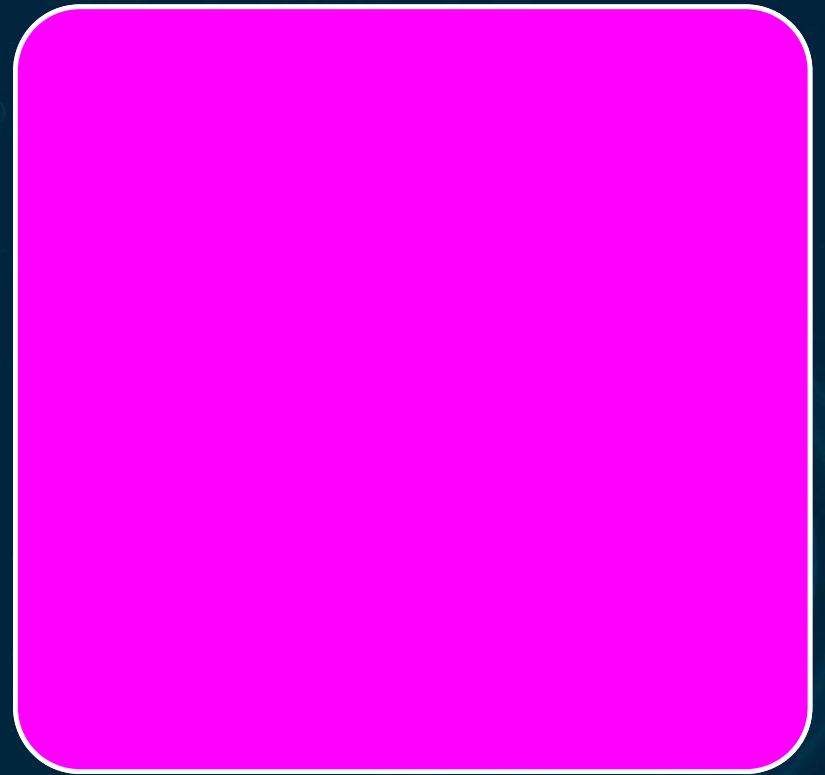
Material risks
above appetite

3

Incident summaries (A/B)

4

Regulatory horizon

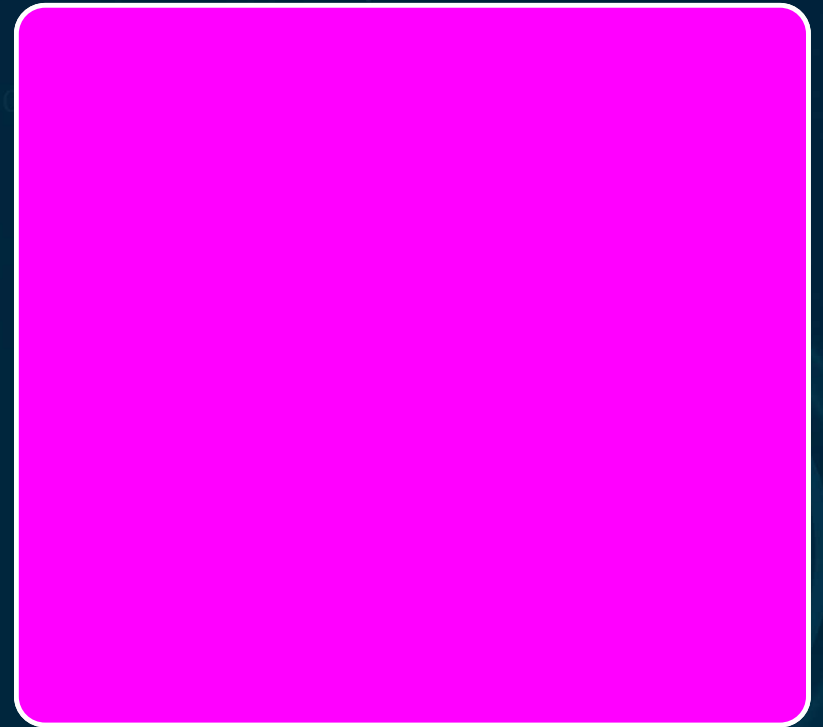


TRIGGER REPORTING

L4/L5 findings → immediate notice

Out-of-cycle: description, response, status

Board notice: L5, enforcement, vendor failure

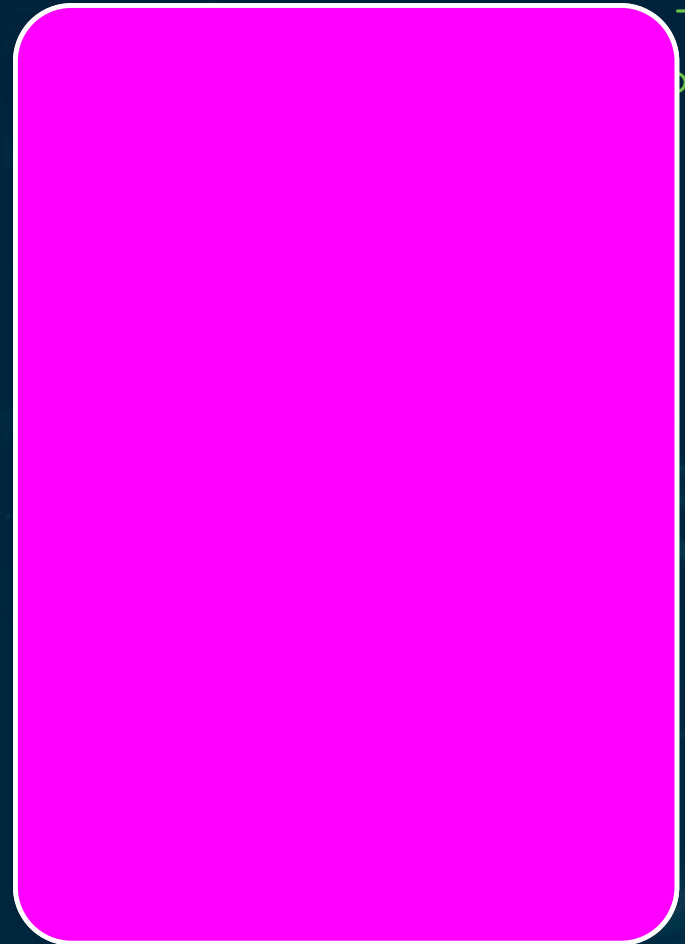


Report Format

Concise, risk-oriented, governance-framed

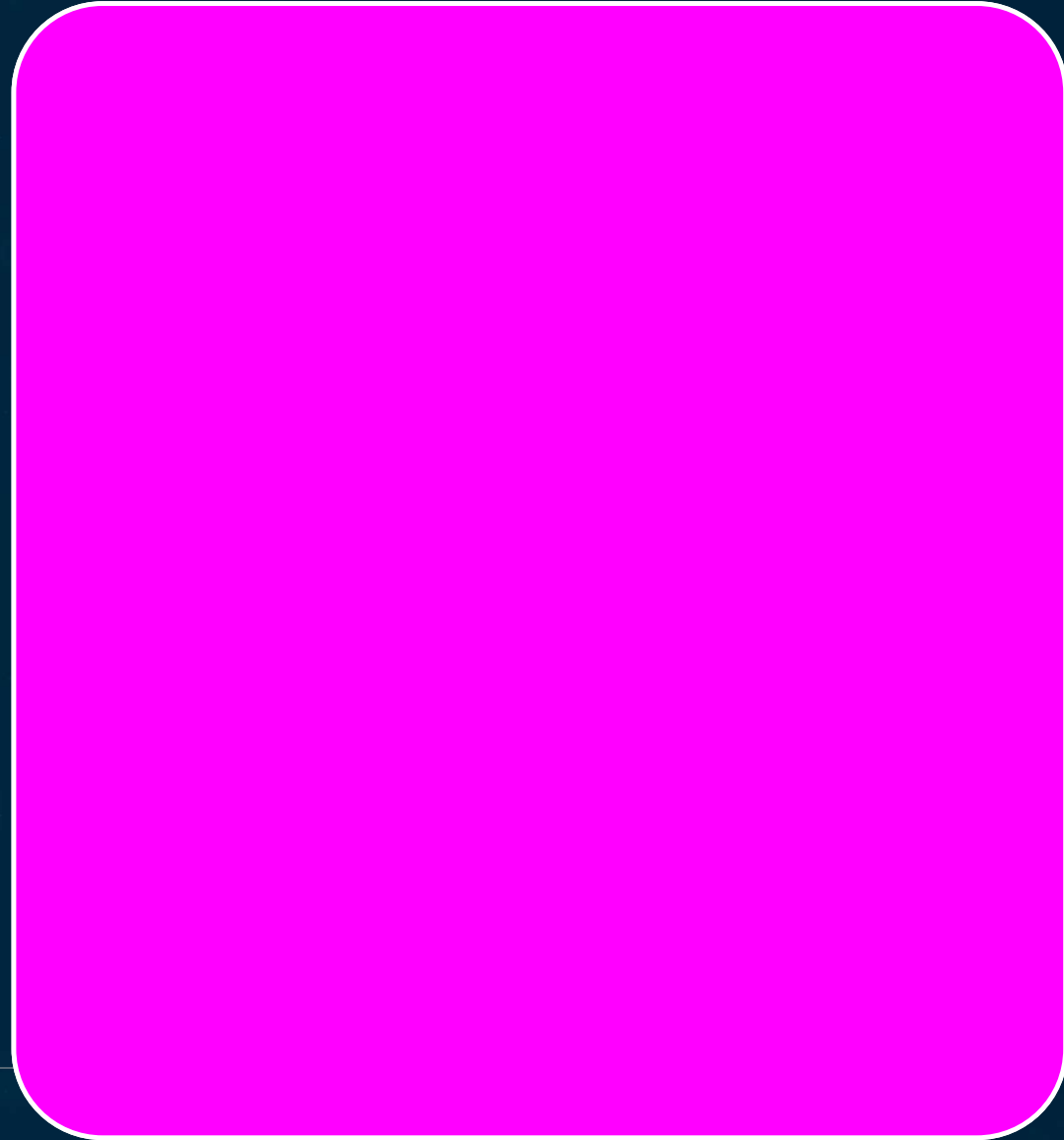
NOT technical — translate to risk

Appetite framework as the anchor



Board Report = Evidence

Retained for audit

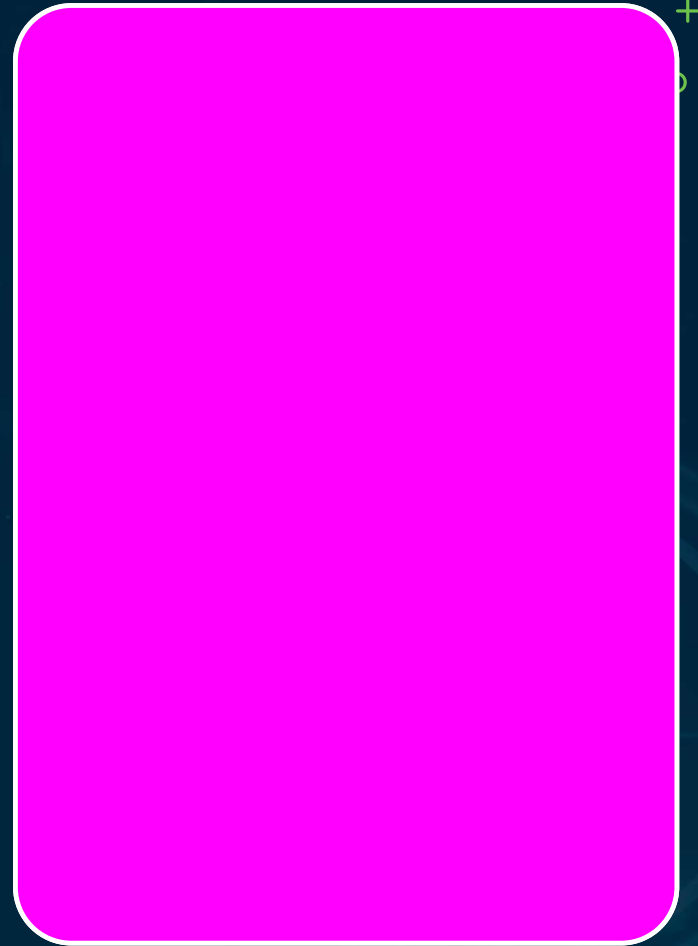


Failures 1–2

Chronic green — 8 quarters, no actions

Technical language execs can't act on

Green is not reassuring

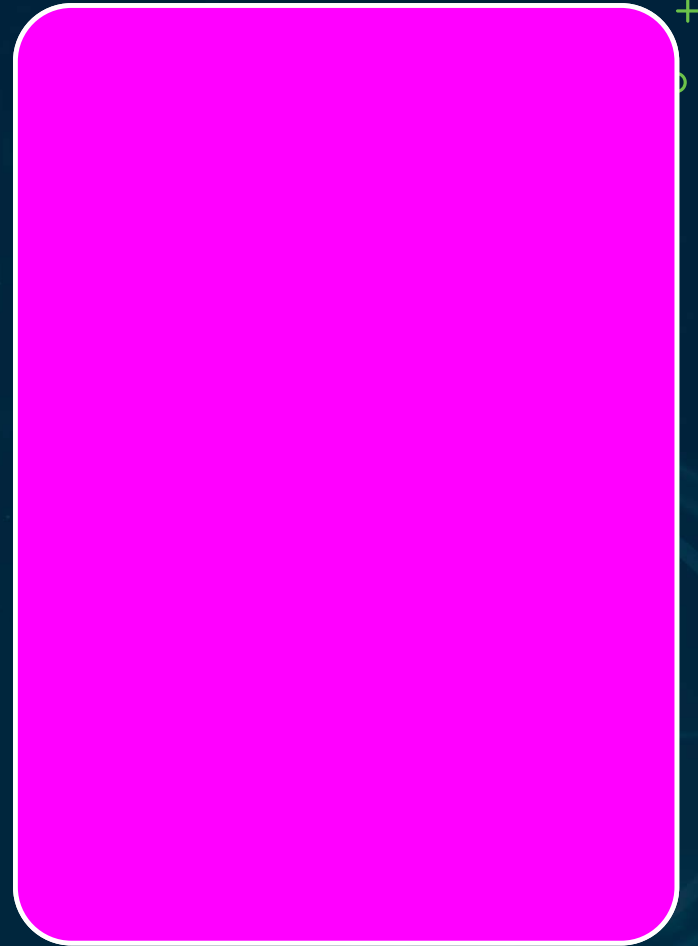


Failures 3–4

No decision items

Late red — managed at amber

Board learns when it's an incident

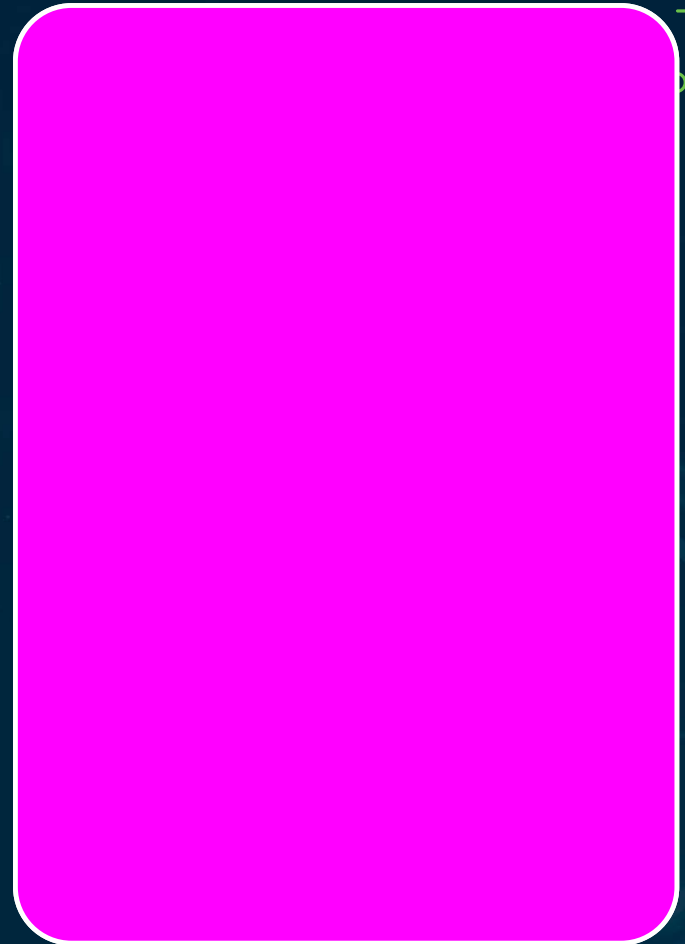


Recap · Module Close

5 report sections & order

3 RAG definitions

Decision brief = 2 options + rec



Executive & Management Reporting

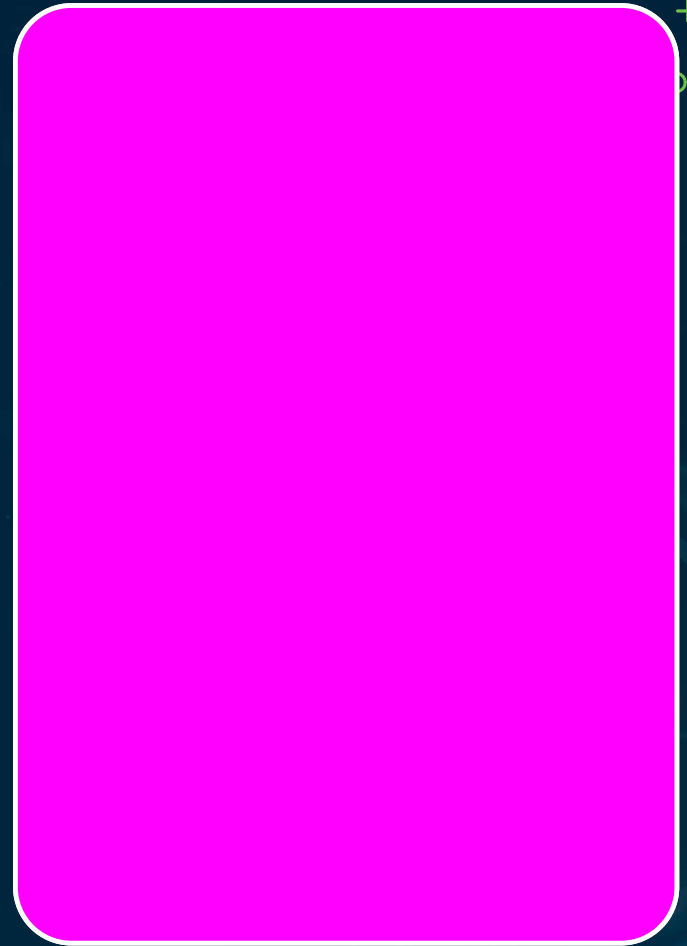
Chapter 03 · Episode 7 — Dr. Michael Solomon



Two Failure Modes

Rubber-stamp approval

Disengagement





What This Episode Covers

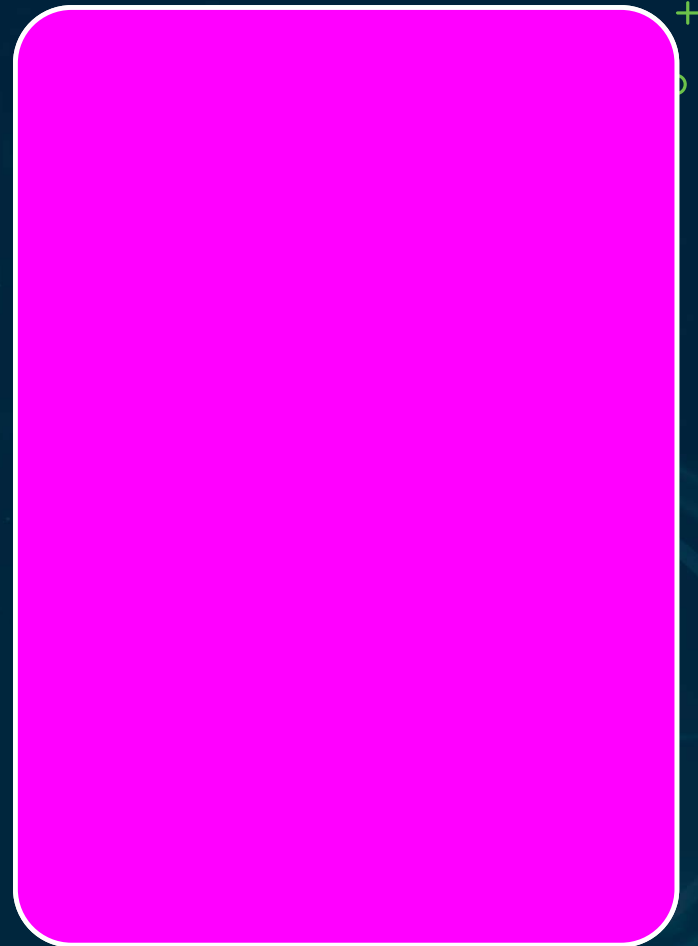
1. 5-section report · RAG status
2. Business translation · decision framing
3. Annual board report · 4 failures

Three Reporting Tiers

Operational — monthly (security lead)

Steering — quarterly (committee)

Board — annual

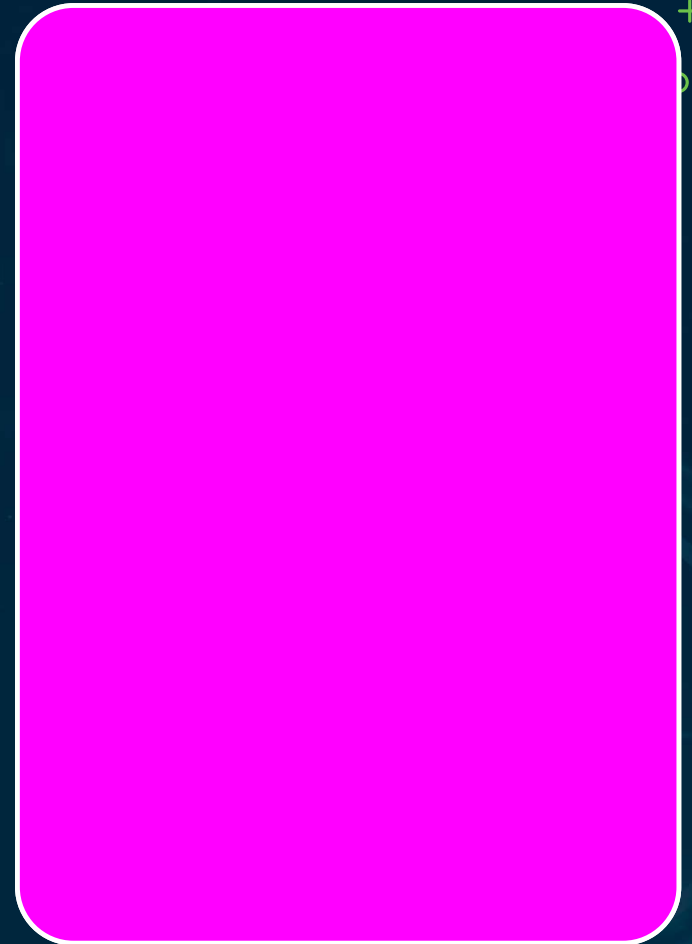


What Each Tier Contains

Monthly: KPI/CRI + L3+ findings

Quarterly: risk register, vendors, incidents

Annual: appetite, maturity, compliance



Board Report Content



1

Appetite vs
actual posture

2

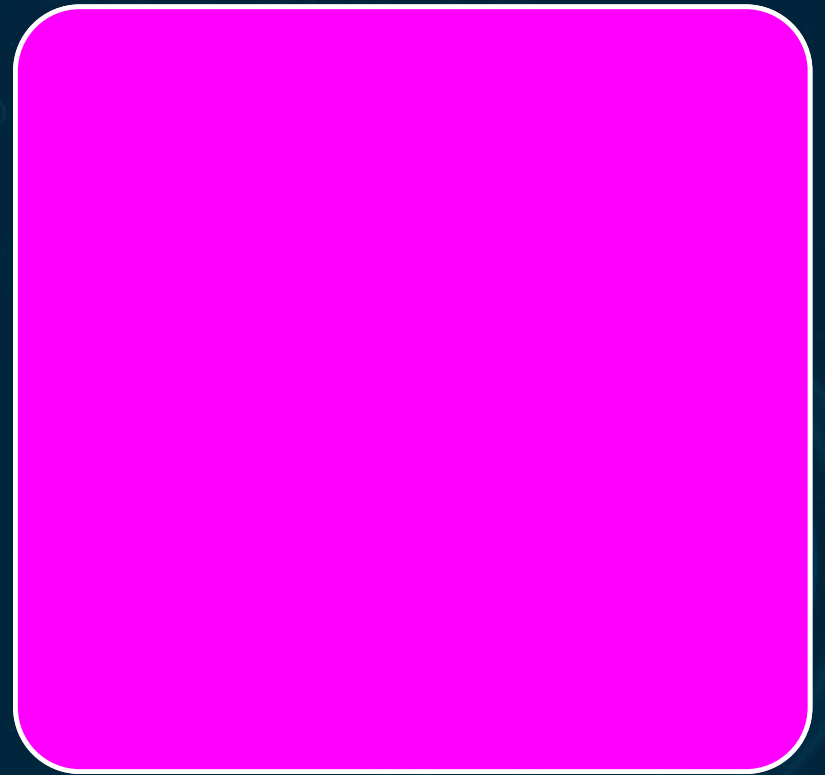
Material risks
above appetite

3

Incident summaries (A/B)

4

Regulatory horizon

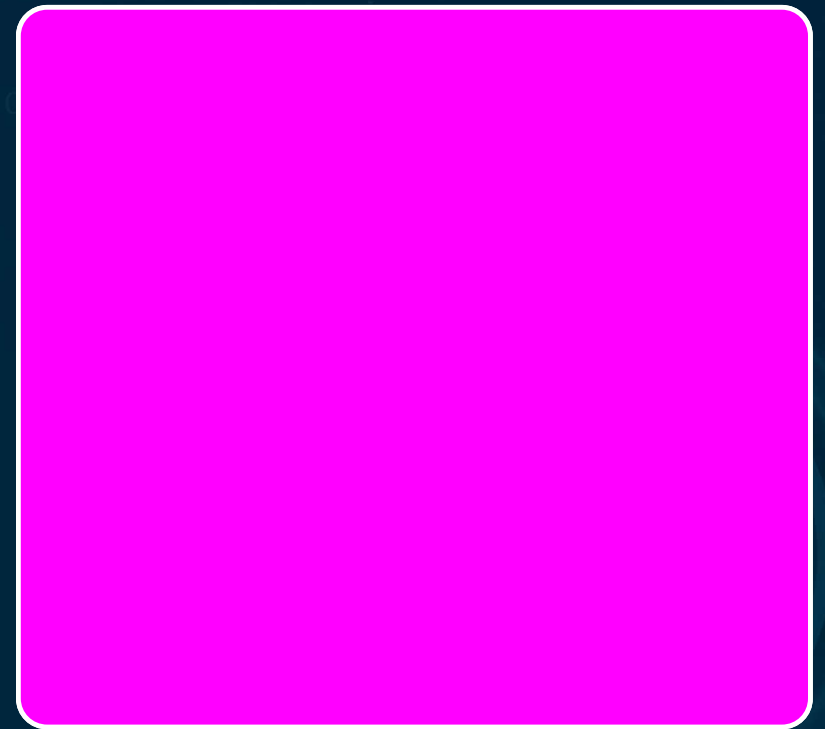


TRIGGER REPORTING

L4/L5 findings → immediate notice

Out-of-cycle: description, response, status

Board notice: L5, enforcement, vendor failure

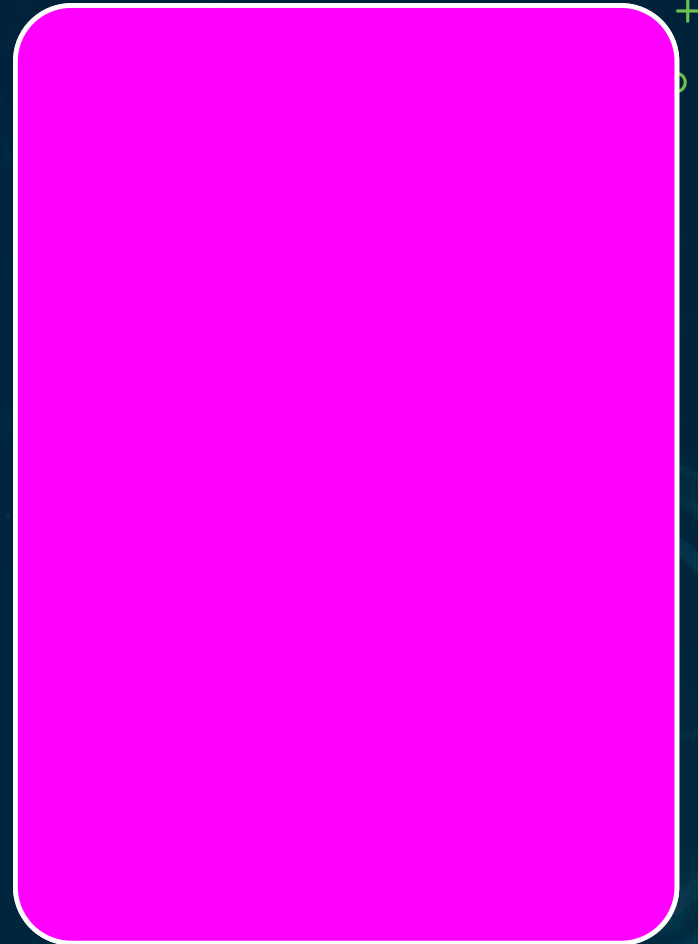


Report Format

Concise, risk-oriented, governance-framed

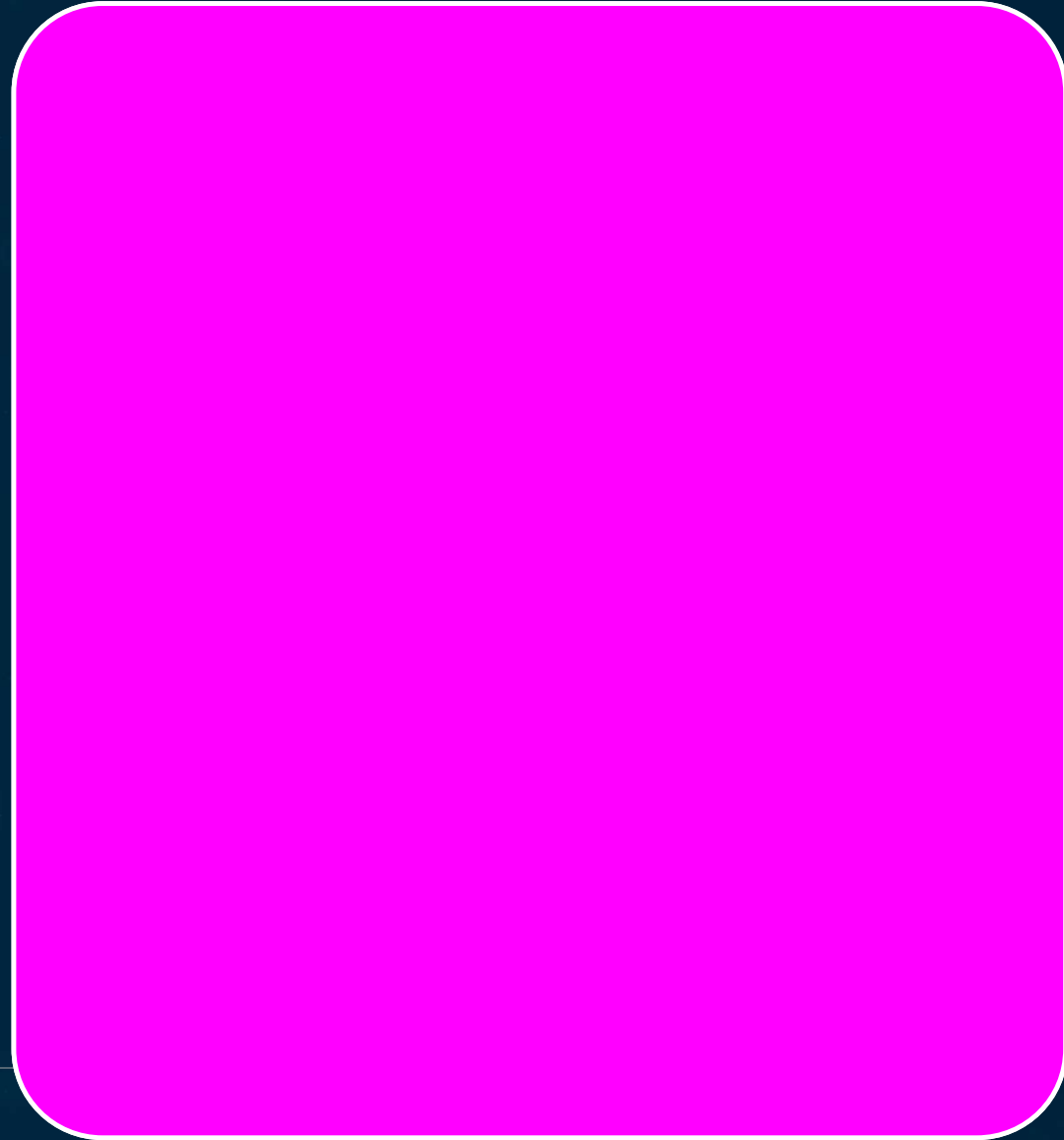
NOT technical — translate to risk

Appetite framework as the anchor



Board Report = Evidence

Retained for audit

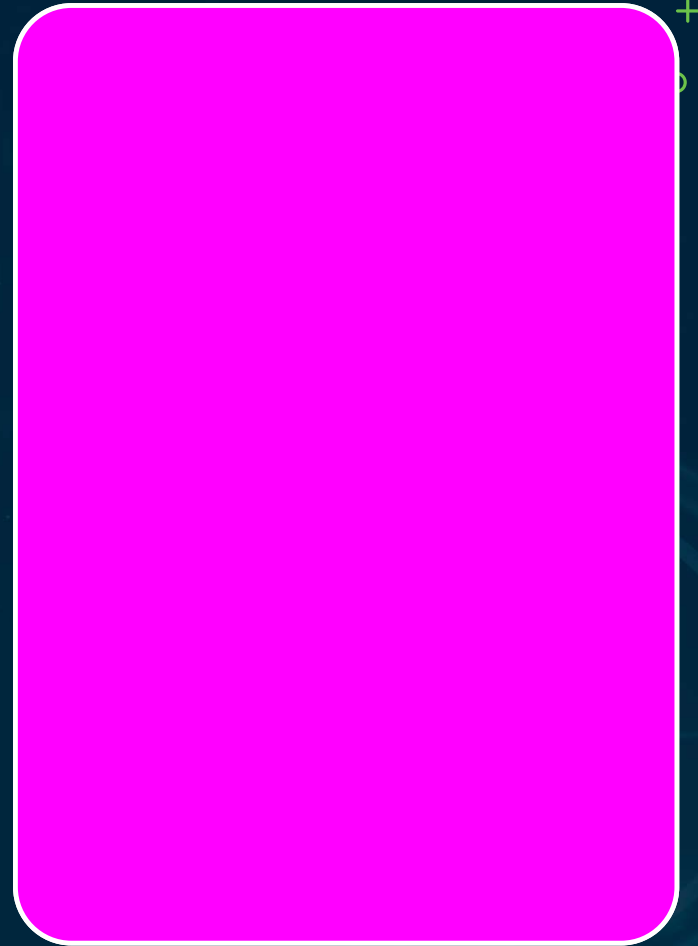


Failures 1–2

Chronic green — 8 quarters, no actions

Technical language execs can't act on

Green is not reassuring

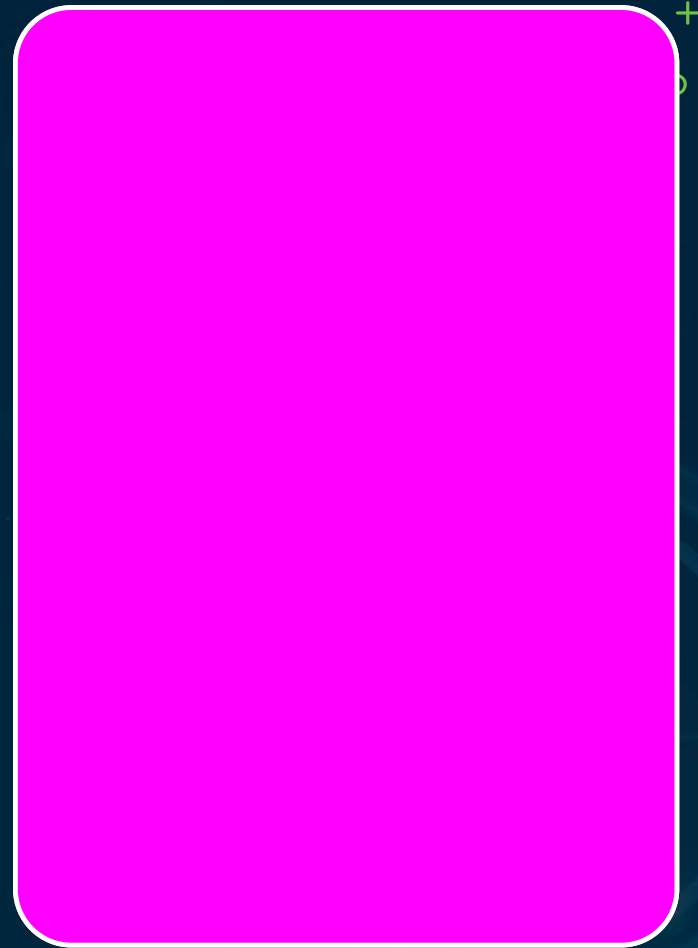


Failures 3–4

No decision items

Late red — managed at amber

Board learns when it's an incident



Recap · Module Close

5 report sections & order

3 RAG definitions

Decision brief = 2 options + rec

